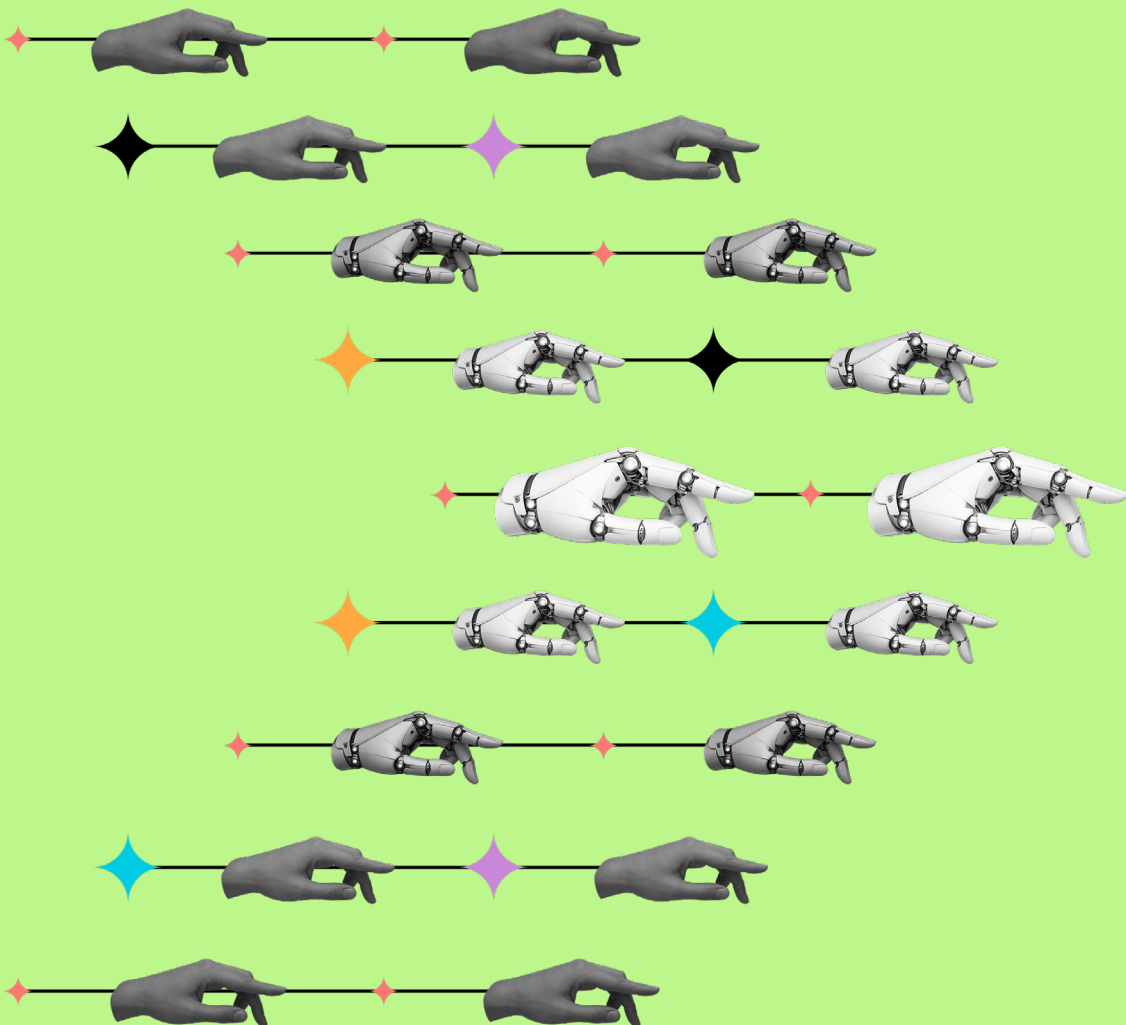


sysdig

2026

Cloud-Native Security and Usage Report

The hustle hard era is over.



Contents

Key trends

03

Executive summary

04

It's time for agentic AI vulnerability management

05

Defending the cloud-native battlefield

12

AI adoption matures

20

Identity is the cloud-native perimeter

31

Growth of the open source runtime security community

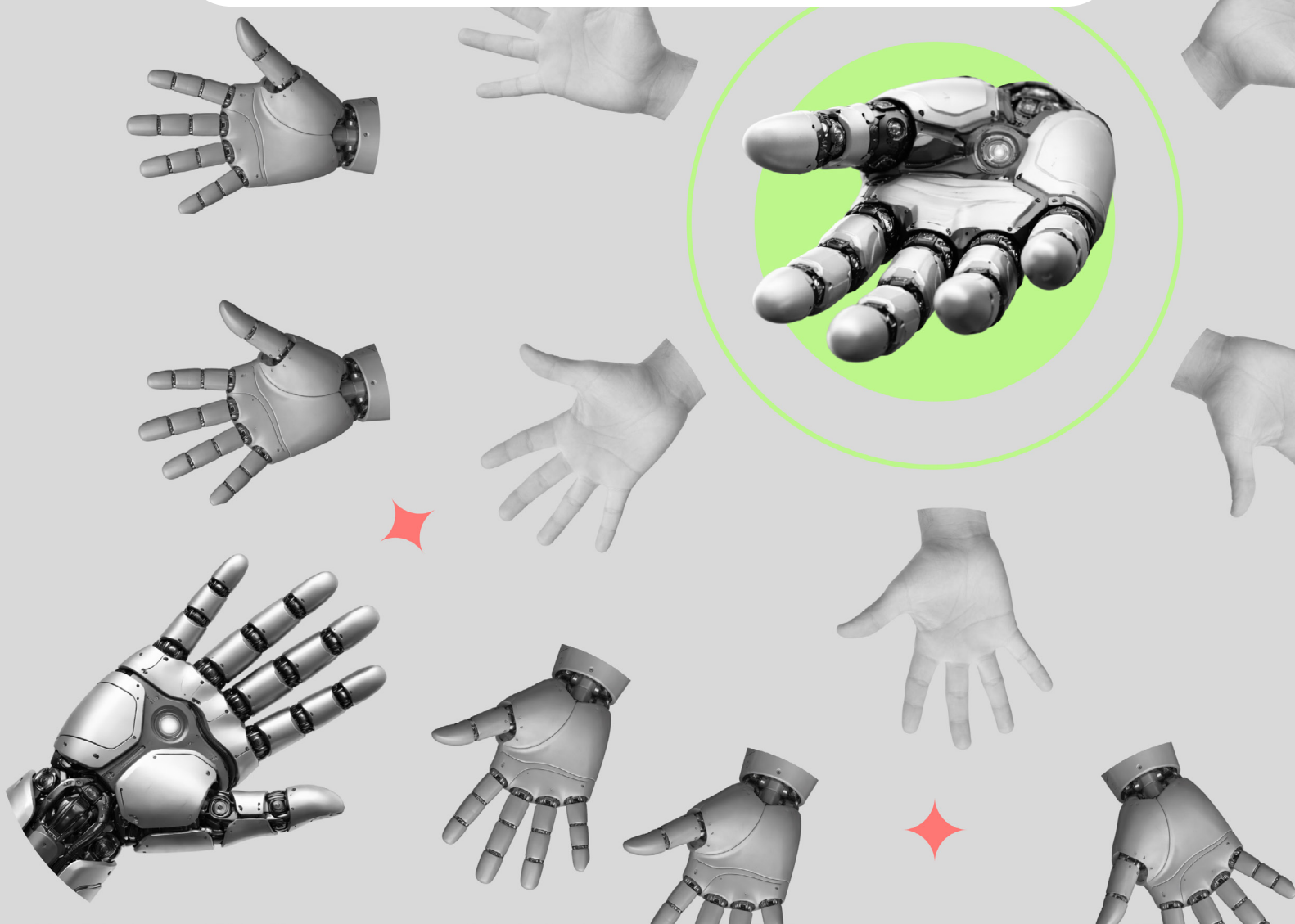
39

Conclusion

45

Methodology

46



KEY TRENDS



Organizations are laying the foundations to scale AI securely

AI-specific packages grew 25x YoY and are building a secure surface with 6x more ML packages, with only 1.5% of these assets publicly exposed.

25x

AI-specific packages grew



Machine-driven operations are defining the modern firewall

Human identities account for just 2.8% of managed identities within CSPs.

2.8%

of managed identities are human



Regulations are accelerating, not stifling, AI adoption in Europe

More than 50% of AI and ML packages belong to European organizations.

>50%

AI and ML packages are European



Organizations are shifting to automated response actions for modern threats

More than 70% of organizations use behavior-based detections across 91% of environments to improve signal quality, and 140% more organizations now automatically kill processes when a detection is triggered.

140%

more organizations auto kill processes when detection is triggered



Even as cloud environments scale beyond human limits, runtime security and build discipline continue to reduce operational risk

Running vulnerable images with known exploits dropped 74% to nearly 0%, and image bloat fell 50% YoY, with less than 1% of packages unused in running images.

50%

less image bloat YoY



Driven by data sovereignty, runtime is the baseline for trust in cloud security

9,000 organizations use Falco, with Europe representing 34%.

9,000

organizations use Falco

Executive summary

Sysdig's team of cybersecurity researchers are back at it with the ninth annual "Sysdig 2026 Cloud-Native Security and Usage Report," and here's the headline: the "hustle hard" era of security is coming to an end.

For years, cloud security has been a race that humans had full intentions of winning through sheer effort, better dashboards, and more caffeine. Even in last year's report, organizations continued to make progress, but the data this year shows that they have officially hit the limits of human scale.

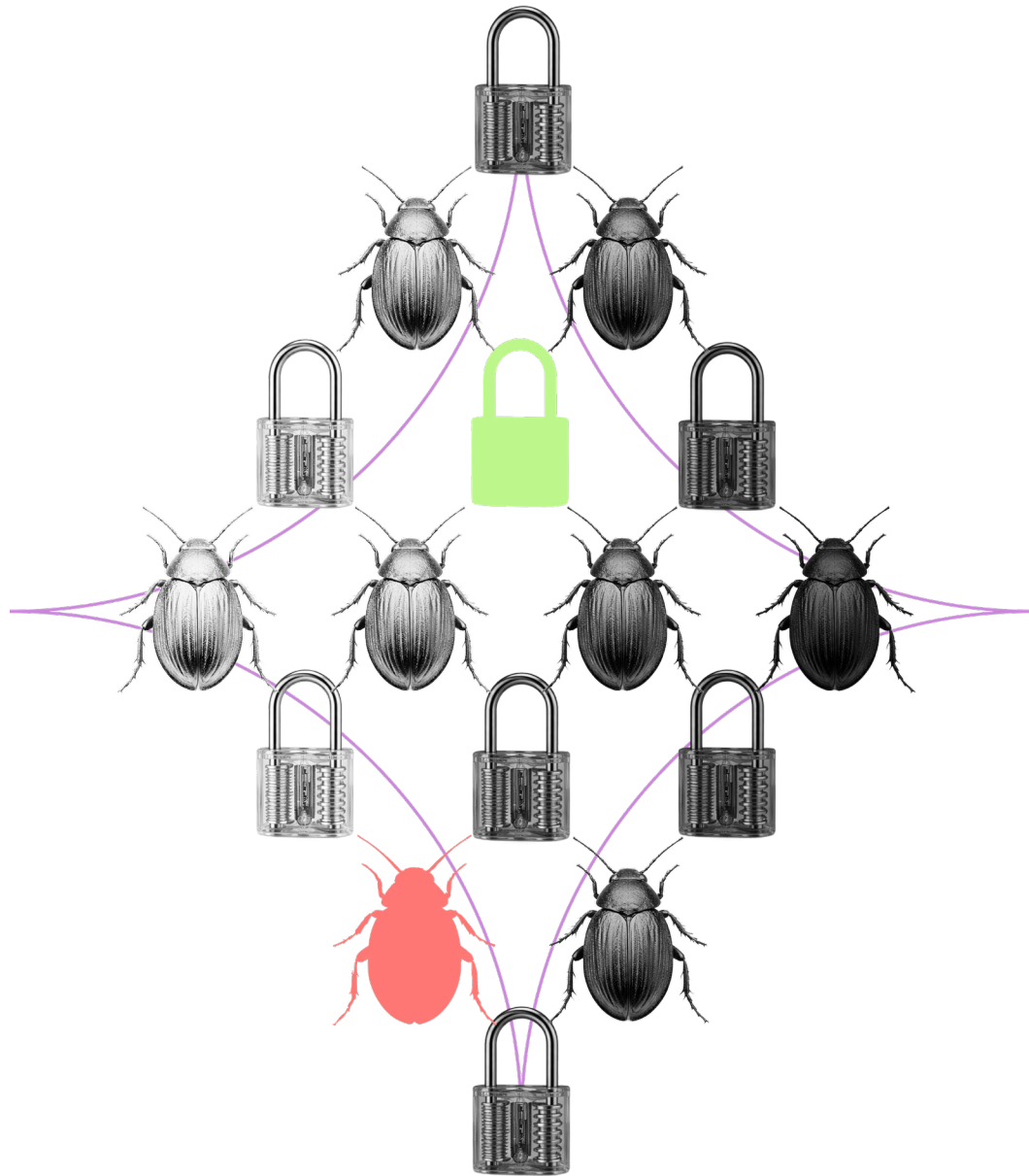
As with Sysdig's past eight reports, this report uncovers what's really happening in the cloud through the analysis of real-world customer data. The findings tell us that while defenders continue to become more sophisticated and automated security is gaining traction, attackers remain relentless, and the human element is still the most significant risk to an organization. Human error, including misconfigurations, is the root cause driving **26% of all data breaches**.

We must face an uncomfortable truth: organizations have optimized human workflows as far as they can, but have reached a vulnerability ceiling despite mature processes. The problem isn't from a lack of effort but a shift in the battlefield. Threats come in at machine speed,

creating proof of concepts and exploiting vulnerabilities like **React2Shell** and BeyondTrust (**CVE-2026-1731**) within hours of disclosure. Any security process, including human input, now introduces delay — and therefore exploitability.

In previous years, security teams moved away from trying to see everything to seeing the right things. Now, the speed of attackers and the introduction of AI in security are forcing some organizations to trust machines with decisions rather than only recommendations. In large enterprises, risk reduction depends more on the use of autonomy than perfection. With too much telemetry, alerts, and attack surface for humans to keep up, doing something that is AI-driven is better than doing nothing at all. Agentic AI is the next step in cybersecurity because at cloud speeds, machine action is becoming more valuable than machine analysis alone.

Strap in. Read on for all of this year's security hot takes and the hard data to back them up.



It's time for agentic AI vulnerability management

When hard work stops paying off

This year's data points to something that a majority of security teams and developers have felt for a while now: **vulnerability management is reaching the limits of human scale**. It's possible that we've reached a threshold for vulnerability management, even with mature tools, improved prioritization, and well-formed processes. The percentage of critical and high vulnerabilities in use remains largely unchanged since last year — a number that had consistently fallen year over year from 2023 to 2025. According to the data, organizations still have approximately 5.5% of vulnerable images present in running workloads this year. That plateau matters, because continued progress requires a new approach to the process.

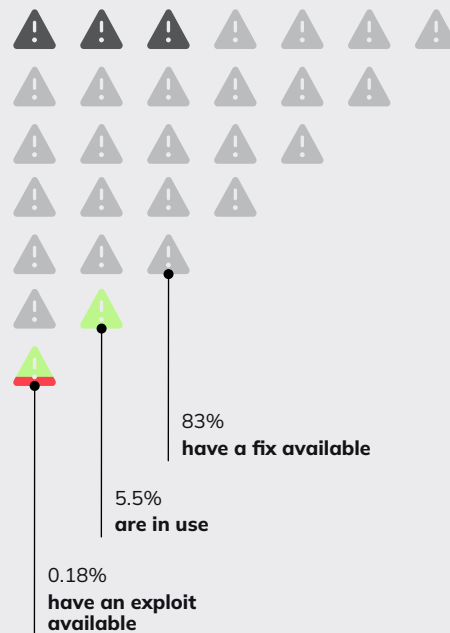
It's a classic case of diminishing marginal returns. In economics, it's what happens when you continue to apply effort but get less and less benefit in return. Early improvements and vulnerability reductions were achievable with better tools and processes, but as environments continue to grow, the curve flattens. The pattern is reflected in today's vulnerability management workflow:

- Vulnerability scanning is automated.
- Ticketing and prioritization are increasingly automated.
- Remediation, however, is still largely human-driven, and it's the limiting factor.

However, this is not a failure of tools nor effort. This is the point at which machines need to be brought in to support human efforts to keep pace with ever-changing cloud-native environments. Some aspects of vulnerability management are automated, such as data correlation and ticket creation, but that's not enough. By implementing a secure and confident agentic AI system within vulnerability management, organizations should be able to continue making progress toward reducing the number of vulnerability risks across their system. To break through the ceiling of 5% vulnerabilities, the next evolution isn't "more automation," it's "smarter, autonomous remediation" orchestrated by agentic AI.

Out of 100 workloads with critical or high vulnerabilities

2026 breakdown

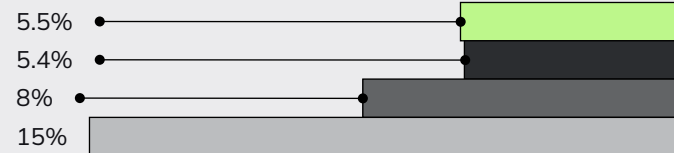


YoY comparison

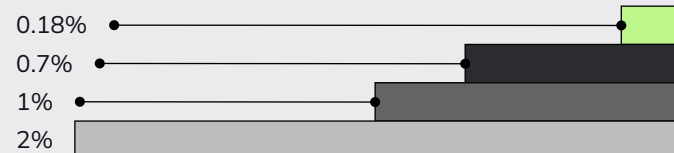
Fix available



In use



Exploit available



■ 2023 ■ 2024 ■ 2025 ■ 2026

Such a shift doesn't mean that vulnerability risk is unmanageable. In fact, there was a significant reduction in the percentage of vulnerabilities with a known exploit. Running exploitable images in production is an unacceptable risk that appears to have been prioritized with nearly a 75% reduction year over year, down to 0.18%. This is a crucial win to highlight for security prioritization: reducing massive risks.

Perfection isn't the goal, however, and it likely never will be. It's unlikely that any classification of vulnerabilities will ever reach 0% with the near-constant evolution of vulnerabilities, exploits, and changing environments. Risk reduction doesn't require perfection — it doesn't mean eliminating *all risk, just all of the right risk*.

Additionally, the window between vulnerability disclosure and exploit weaponization has collapsed, according to [VulnCheck](#). In 2018, attackers took nearly a year to weaponize vulnerabilities. By 2023, it was only eight days. At the end of 2025, React2Shell was being actively exploited only hours after it was disclosed. As attackers continue to use AI in their operations, vulnerability weaponization will approach near-real time.

Breaking through the ceiling, removing the most dangerous vulnerabilities, and continuing to reduce real risk is where agentic AI becomes not only useful, but economically and operationally justified. Autonomous remediation, executed within human-driven guardrails, is how organizations will keep pace with shrinking exploit timelines.

What are the right human-defined guardrails?

Humans can still guide agentic processes. Advocating for agentic security does not mean removing humans from the loop; it simply means redefining their roles. Humans can define the following:

- Write policies to define change limits.
- Scope permissions and privileges.
- Deterministic rollbacks.
- Audit logs, output, and explainability of agents.
- Risk thresholds with environmental context.

Without guardrails, agents will introduce operational risk at some point in their lifetime. Humans can advance with machine-speed security when they define and govern it.

How security maturity breaks down bloat

Organizations are prioritizing and cleaning up the security mess left behind by the AI boom of 2025. That is, the excessive number of unused packages that come along with open source images but do nothing for your organization's use case. Last year's report called for shrinking image bloat through consolidation, smart application building, and the discovery of shadow AI and other shadow IT.

After analyzing nearly 13 billion packages for image bloat, less than 1% of packages in images were unused, a reduction of 50% year over year. Organizations are maturing their continuous integration/continuous delivery (CI/CD) pipelines and adopting leaner images, which in turn reduces their attack surface. Simultaneously, they can save a few bucks because smaller images build, scan, and pull faster, leading to faster-moving pipelines and less developer wait time. Lighter images also take up less storage, resulting in cost savings for registries and artifact repositories.

Again, while the expectation is that this may never reach 0%, organizations are smartly cutting unnecessary risk. Reducing the complexity of images can be a machine-scale strategy: fewer packages and fewer surprises result in faster patching or resolution and clearer ownership.

The challenge lies in securing these CI/CD pipelines, where attackers **made it a point in 2025 to identify and exploit weaknesses**. CI/CD pipelines are integral to developer workflows but often have broad permissions across source code, build systems, artifact repositories, and production infrastructure. For attackers, they represent high impact and low visibility, which offers them several strategic advantages:



Privilege

Pipeline credentials often allow write access to repos, container registries, cloud resources, and production environments.



Movement

A single CI/CD compromise can impact every application, service, or customer using the affected artifact.



Persistence

An attacker can embed malicious code into build processes or artifacts, letting the malware survive redeployment and bypass some runtime defenses.



Trust

CI/CD outputs are too often assumed “safe,” which allows lateral movement downstream without triggering alerts.

As cloud-native environments continue to become interconnected and automated, CI/CD pipelines increasingly function as the connective tissue between code, infrastructure, and production, requiring a high degree of defense and collaboration between security and development.



The Cloud Defense Report 2025

A Look Inside the AI-Powered Security Shift

UNLOCK THE FULL REPORT >>>

Cloud attacks are accelerating. Vulnerabilities are compounding. And artificial intelligence (AI) is not only reshaping the attack surface, it is reshaping expectations. Welcome to security in 2025.

Security leaders today face a shifting paradigm. While organizations are demanding innovation and urging every function to “do more with AI,” their security teams are being stretched across three fronts to:

- Secure the AI being rapidly adopted across the enterprise.
- Integrate AI into the security stack to accelerate workflows.
- Defend against AI-powered threats that unfold not in hours, but minutes (or possibly even seconds).

To meet this moment, security leaders must move beyond the outdated trade-off between speed and safety. AI-powered attacks are reshaping the threat landscape and the expectations for defense. Assume breach is now the baseline mindset, and real-time, continuous defense is no longer a competitive advantage – it is a requirement.

The data is clear: the modern cloud security landscape is underpinned by three powerful, interconnected forces: AI, visibility at runtime, and open source pushing security forward. AI attacks continue to move faster and grow more sophisticated and less predictable, robust security is rooted in collaboration, knowledge of what is actually running in production workloads, and AI that simplifies security processes and helps defenders move as fast as the attackers they’re up against.

60%

of containers live for one minute or less

76%

faster mean time to respond when using AI for security incidents

300

of the Fortune 500 use open source Falco

Stop real threats in real time

Learn more in the Cloud Defense Report

[READ THE REPORT](#)

A vulnerable operating system paradox

In reviewing the top host and container operating systems with critical vulnerabilities, the majority are **not** end of life (EOL). In fact, the newest, actively maintained operating system (OS) versions show the highest concentration of reported critical vulnerabilities. Non-EOL hosts account for 80% of the top 10 OSs with critical vulnerabilities. Similarly, non-EOL container OSs contain 75% of critical vulnerabilities in the top 10. Risk lives where innovation grows.

This does not indicate that modern OSs are less secure. Rather, it may be because vulnerabilities are reported less when an OS hits EOL, or because threat actors and security researchers alike prioritize targeting and securing the newest versions. Modern infrastructure is simply more complex and more valuable.

Modern OSs are where real-world, innovative workloads are running, making them the highest-value targets for discovery, exploitation, and defense. Additionally, the increasing complexity of modern OS kernels, libraries, and container runtimes expands the potential attack surface, providing more opportunity to find flaws.

Top 10 host OSs with the most vulnerabilities

● Amazon Linux 2 (Karoo)	38.4%
● Ubuntu 22.04	24.7%
● Ubuntu 20.04	13.4%
● Redhat 9.6	5.8%
● Ubuntu 24.04*	5.3%
● Oracle 8.10	4.4%
● Ubuntu 18.04*	3.6%
● Centos 7.9.2009	2.0%
● Amazon Linux 1 (AMI release 2018.03)*	1.5%
● Centos 7.6.1810*	1.0%

Top 10 container OSs with the most vulnerabilities

● Debian 12.12	41.2%
● Debian 10.9*	18.3%
● Debian 12.11	14.8%
● Debian 11.11	8.3%
● Debian 11.4	4.5%
● Alpine 3.19.0*	4.1%
● Ubuntu 24.04	3.5%
● Debian 12.10	3.3%
● Redhat 8.10	3.0%
● Ubuntu 22.04	2.9%

* End of life

Key takeaways

Our vulnerability data makes one thing clear: we have a scale problem. Remediation, coordination, and verification are still human-driven, and while the reduction in known exploited vulnerabilities and image bloat shows that organizations are capable of cleaning up risk debt when they focus, it's still causing a bottleneck.

This is the inflection point. Manually closing loops is giving way to autonomous systems that can continuously and safely remove the mechanical toil so that humans can govern risks, not chase them.

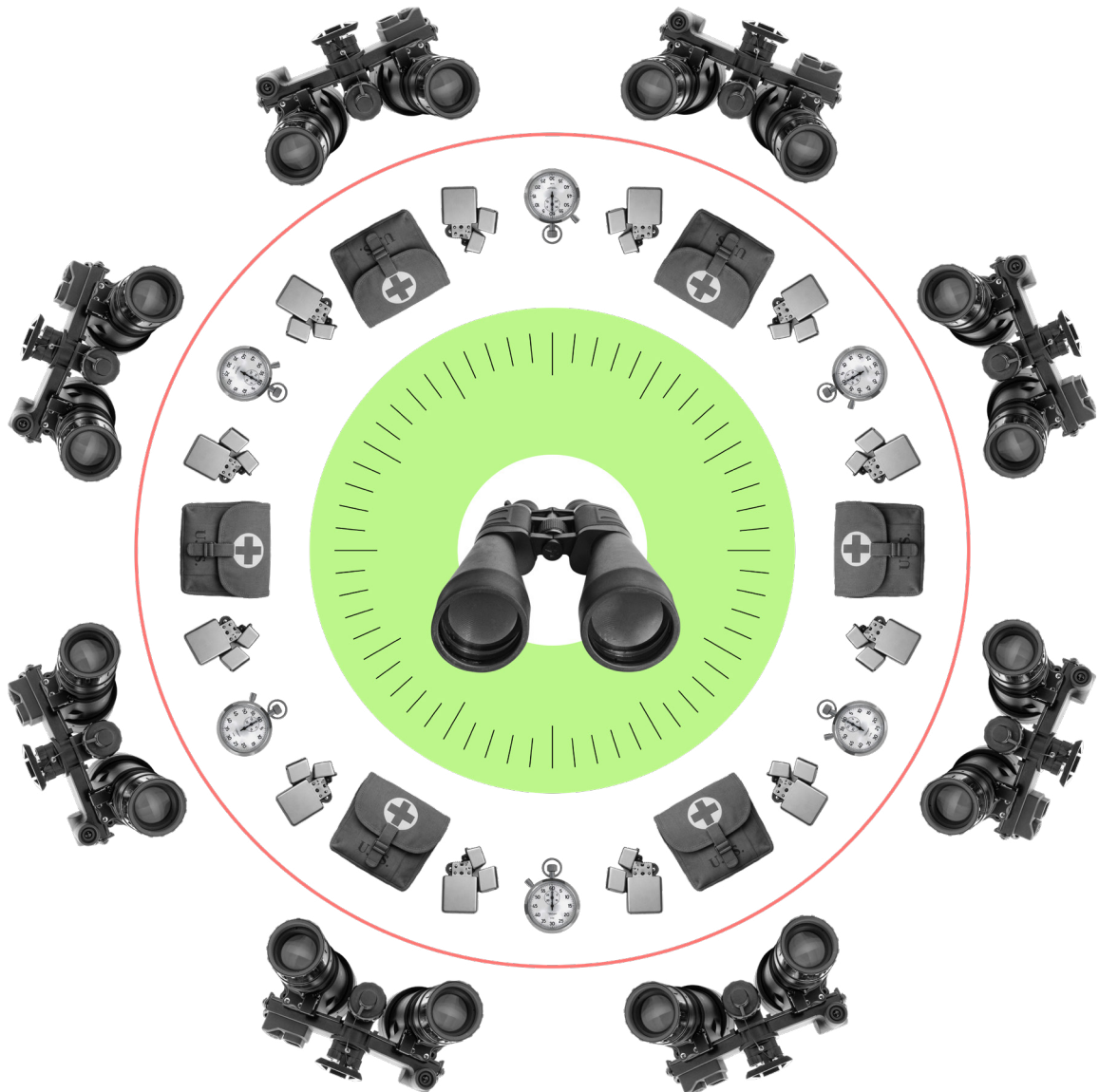
CI/CD pipelines, for example, represent systemic risk in which one compromise can cascade downstream and across environments. The more interconnected and automated cloud-native environments become, the less feasible manual oversight becomes.

There are early proof points that AI can drive remediation and patching at scale. Agentic coding is accelerating software development, compressing the time between code creation and deployment. Human-paced patching will not keep up.

Next steps

The hustle hard era is ending as scale continues to grow. It's time for people to focus on setting a strategy and defining an acceptable risk tolerance in order to:

- Shift from AI-enabled prioritization to AI that can execute remediation actions.
- Define and apply guardrails and allow AI to patch and make secure configuration changes to keep pace with the speed of agentic software development.
- Embed AI-driven policy enforcement into pipelines and across permissions and credentials.
- Treat remediation timescales as a business key performance indicator (KPI) and measure real risk reduction instead of ticket closure rates.



Defending the cloud-native battlefield

Cloud-native environments are distributed, ephemeral, and constantly changing. Over the past several years, we've learned that defending these dynamic environments is no small feat. It demands more than just visibility. **It requires the right prioritization, behavioral correlation, and the ability to act with speed.**

Year after year, security teams have improved their defensive processes. This year's data also shows meaningful leaps in maturity to match the speed of cloud attacks. More organizations are increasingly strengthening their runtime defenses by using more precise detections and accelerating the shift toward automated response.

Organizations prefer behavioral detection fidelity

Many triggered detections are often the result of developers or engineers simply trying to do their job: a container spawning a shell, a process accessing sensitive files, or an identity elevating privileges. These false positives create a lot of noise for security teams and lead to the infamous *alert fatigue* that many security operations center (SOC) analysts feel day in and day out. Indicator of compromise (IOC)-based detections are not good enough for today's advanced threat actors, and neither are alerts that trigger on a single action. A single behavior seen in isolation rarely tells the full security story. Without context and correlation across workloads, identities, and runtime, security teams are left chasing signals that are either benign or obsolete by the time they're noticed.



More than 70% of organizations are using stateful detections

High-fidelity detections are built around multiple actions or a chain of events. **More than 70% of organizations are using stateful detections, or behavior-based rules, across 91% of their cloud environments.** The high usage of stateful detections is a clear validation that behavior-based rules are the modern standard for evaluating fewer high-fidelity alerts over raw volume. And this shift is not just about reducing noise. Once the security team trusts the signal, the next natural step is to trust the action.



Sysdig offers threat detection via Amazon Web Services (AWS) Behavioral Analytics, which is of course specific to organizations operating with this cloud service provider (CSP). These detections monitor the cloud control plane and will detect anomalies with API calls, identity usage, configuration changes, and more.

AWS stateful detections across regions

AMER
69.6%

EMEA
72.4%

APAC
75.5%



The Falco agent supports stateful detections with the ability to correlate and contextualize events. These detections are called Sysdig Runtime Behavioral Analytics, and they can be used with any CSP and operate at the Linux and container runtime layers. These detections trigger on irregular system calls, process behaviors, file activity, and container drift.

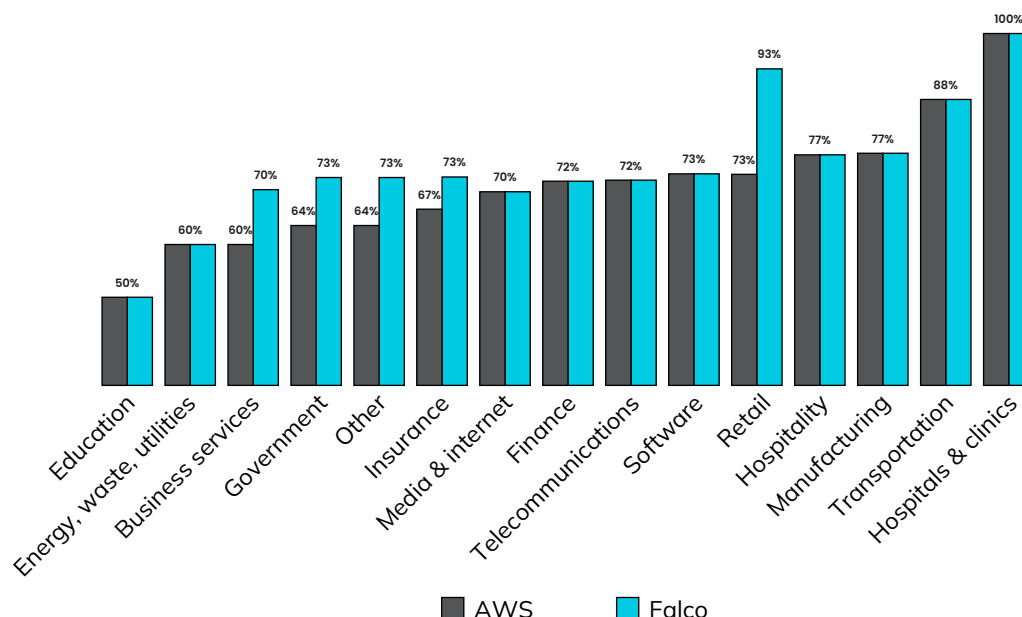
Falco stateful detections across regions

AMER
70.1%

EMEA
74.2%

APAC
77.5%

Stateful detections across business sectors



It's clear that organizations across all business sectors see the value in stateful detections; the sectors above are typically targeted most often by threat actors, and likely to cut through the noise and identify actual threats faster. These include finance, hospitality, healthcare, manufacturing, and transportation. A majority of the organizations within these sectors also fall under critical infrastructure according to many regulations; therefore, detecting threats quickly so that they can report incidents is also a high priority for compliance and business continuity in addition to security.

While overall adoption of stateful detections is high, it's important to note that organizations that do not operate in AWS environments will reduce the regional and business sector percentages. In some cases there is little added value, and stateful detections are disabled. Sysdig Runtime Behavioral Analytics adoption is slightly higher across the board because organizations using all CSPs can use them.

The use of stateful detections is the foundation for the future of AI-driven detection and response. AI alone will only amplify noisy and inconsistent data. Stateful detections provide the contextual and correlated information that AI systems need to distinguish benign from anomalous behavior.

The rise of autonomous response

Automation used to mean tickets and dashboards; now it means decisions. For three years we've been reporting on automated incident responses such as killing, pausing, or stopping a container, and every year we've seen an increase in the number of organizations using these actions for an increasing number of runtime detection policies. Slowly but surely, organizations are either becoming increasingly confident in their ability to respond to potential incidents autonomously, or they feel pressured and see no choice but to automate some responses.

Automated response can be implemented at different levels based on organizational confidence:



The shift from manual reaction to autonomous action is the ultimate sign of cloud security confidence and maturity as organizations shift to the distributed, immutable, ephemeral (DIE) operating philosophy. There is opportunity in incident response to continue building trust in machines offering recommendations and making decisions, because an action — even if agentic-driven — is better than taking no action.

Together, process-level and container-level termination offer graduated autonomous response options, allowing organizations to match the response to the scope of the threat, rather than defaulting to full workload disruption that could cause operational impact.

While 75% of organizations have automated response actions configured for various policies, they aren't being actively used or implemented. Only 27% of organizations have automated responses implemented. The vast majority of organizations only configuring automated responses is a sign of intentional caution, where businesses are likely actively working toward confident automation and following DIE, or the idea that an immutable workload should never change during runtime. The next step for many organizations is overcoming this trust barrier, where they fear breaking a production workload. In practice, this means that any observed runtime change in an immutable workload is evidence of potentially malicious activity.

The preference to “kill” over “pause” or “stop” is a sign of maturity, indicating prioritizing security over the operational convenience of troubleshooting a running, compromised container.



The most significant change was in the autonomous use of the “kill -9” command to kill a process following a threat detection alert. There was a 140% increase in organizations using the command across 132% more policies than last year when this policy was first enabled. Killing a process is a low-blast-radius containment action that allows defenders to interrupt an attack without disrupting the entire workload. It shows growing confidence in detection fidelity and a clear preference for precise containment with localized compromise.

At the workload level, there was a 28% increase in the number of organizations that favor killing a container as opposed to pausing or stopping, applied across 69% more policies than last year. The preference to “kill” over “pause” or “stop” is a sign of maturity, indicating prioritizing security over the operational convenience of troubleshooting a running, compromised container.

Additional gains in prevention via system hooks reinforce this trend toward decisive, automated action, including a 9% increase in organizations autonomously preventing drift and a 37% increase in preventing malware.

The future of machine-scaled security isn't reckless. The graduated autonomy seen over the past few years has been driven by confidence in detection fidelity.

Manual mitigation is a race against the clock

Is your environment impacted by the latest vulnerability to hit the news (or quietly slip past the headlines)? Newly identified vulnerabilities or threat actor campaigns typically require some investigation or threat hunting to identify impact, unless you have a security provider automatically adding detection rules for you.

Velocity, not novelty, is more often a threat actor's advantage. Fast iterations and a successful path are more useful than the perfect plan, as the Sysdig Threat Research Team (TRT) saw in December 2025 with React2Shell attacks happening only hours after the vulnerability was made public. The longer it takes to remediate a vulnerability, the greater the risk that your environment could be breached. Being proactive and prioritizing properly is key.

The Sysdig TRT adds widespread and relevant threats to its Threat Intelligence Feed to give customers a clear summary, impact insights, and direct links to drill down into affected workloads, packages, identities, and hosts. Of the threats identified and published to the Threat Intelligence Feed for Sysdig Secure customers:

- 39.8% were reviewed in less than 24 hours.
- 16.6% were reviewed in 25 to 47 hours.
- 23.3% were reviewed in two to seven days.
- 20.3% were reviewed in one week or more.

The delayed review of intelligence could be because the vulnerability did not pertain to the environment or because it was a lower priority. However, more than half of the threats identified were assessed in less than two days. Organizations should use this evaluation as a benchmark for active threat intelligence consumption — keeping in mind that exploitation can happen quickly following vulnerability disclosure, as it did with React2Shell. This is proof that vulnerability management and threat detection need to be autonomous and real time.



39.8% reviewed in less than 24 hours

16.6% reviewed in 25 to 47 hours

23.3% reviewed in two to seven days

20.3% reviewed in one week or more

Key takeaways

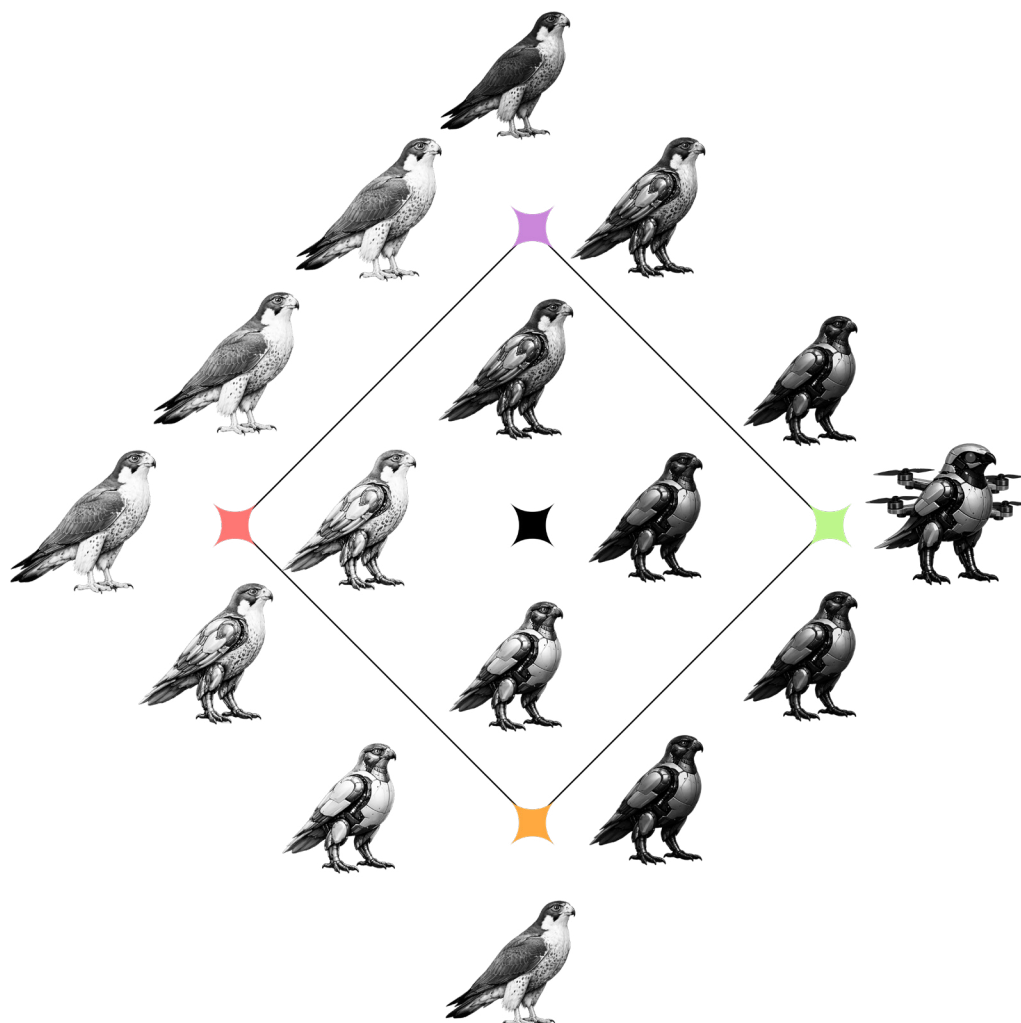
Cloud-native defense continues to mature. The security industry is painfully aware that manual validation and response cannot keep up with machine-speed attacks. The data proves that organizations are shifting toward high-fidelity, stateful detection, and they are increasingly confident in automated

response and containment. This is real progress. Human-driven detection, investigation, and mitigation are giving way to autonomous detection, contextualization, and response, alongside simultaneous human-driven validation. Security's role is shifting from reacting to governing a scaled defense.

Next steps

The next step is putting the right foundations in place to:

- Continue shifting from IOC-based signals to stateful, behavior-based detections.
- Implement an agentic response system that can validate alerts and execute remediations.
- Treat detection fidelity not just as a noise reducer, but as a prerequisite for autonomous response.
- Measure response and containment speed and latency as a business KPI in addition to alert volume and manual ticket closures.
- Establish clear guardrails to allow automated response without operational instability.



AI adoption matures

AI is now an invaluable tool in the arsenal of both attackers and defenders. Threat actors use it for more than just enhanced social engineering campaigns and reconnaissance. The Sysdig TRT has found a malware script that was up to 95% AI-generated and an AI-assisted account takeover in less than 10 minutes.

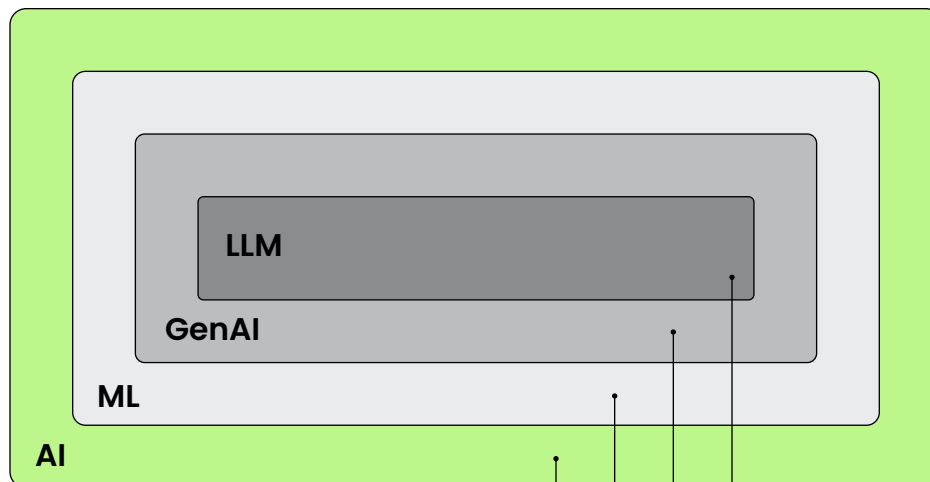
Luckily, defenders are hot on their heels. Organizations are using AI across the entire security life cycle to accelerate the most time-consuming parts of cloud security: investigation, triage, vulnerability management, and response. Sysdig Sage™ correlates runtime activity, vulnerabilities, remediations, identities, and cloud resources quickly, giving security teams immediate context for active threats. This enables Sysdig customers to reduce mean time to respond (MTTR) by 76% compared to pre-AI security workflows.

Organizations are also maturing quickly in their AI usage. A majority of organizations are building their own AI stacks and orchestrating complex workflows. Tasks that previously took hours of manual analysis can now be completed in minutes, helping defenders keep pace as attackers automate and accelerate.

The first widely adopted use case for AI in security, including Claude Code, was scanning code to find vulnerabilities. Sysdig extends this approach by detecting abuse of the agents themselves at runtime. As AI agents are integrated into workflows, new attack surfaces emerge: they may download malicious components or attempt to escape their sandbox to impact underlying systems. Runtime detection makes it possible to identify and respond to these behaviors immediately.

But while AI innovation is being implemented quickly and AI capabilities are evolving rapidly, securing AI is far less revolutionary than it seems. As explained in **"AIBOM: The Infrastructure, Risks, and How to Secure AI Models,"** there's nothing fundamentally novel about AI infrastructure. What it takes to secure an AI model is largely unchanged from the cloud security practices we all know (and may or may not love). The problem lies less in the new technology, and more in the old security habits that die hard (still).

This hierarchy of AI systems is defined by the kinds of problems each system is designed to solve, not the underlying hardware or tools. Before digging into what defender usage looks like this year, let's define the nested categories of AI systems. Each is a more focused subset of the one below it.



AI — AI is the umbrella term that refers to any system designed to perform tasks that used to require human intelligence, such as reasoning, pattern recognition, decision-making, and more.

Machine learning (ML) — Dominates modern AI in practice. Most AI systems are ML-based. Rather than relying on programmed rules, ML learns patterns from data and improves performance over time based on learned experience.

Generative AI (GenAI) — Learns structure from its training data and produces novel content.

Large language model (LLM) — Answers questions, translates, provides summaries, writes code, and can reason to some degree.

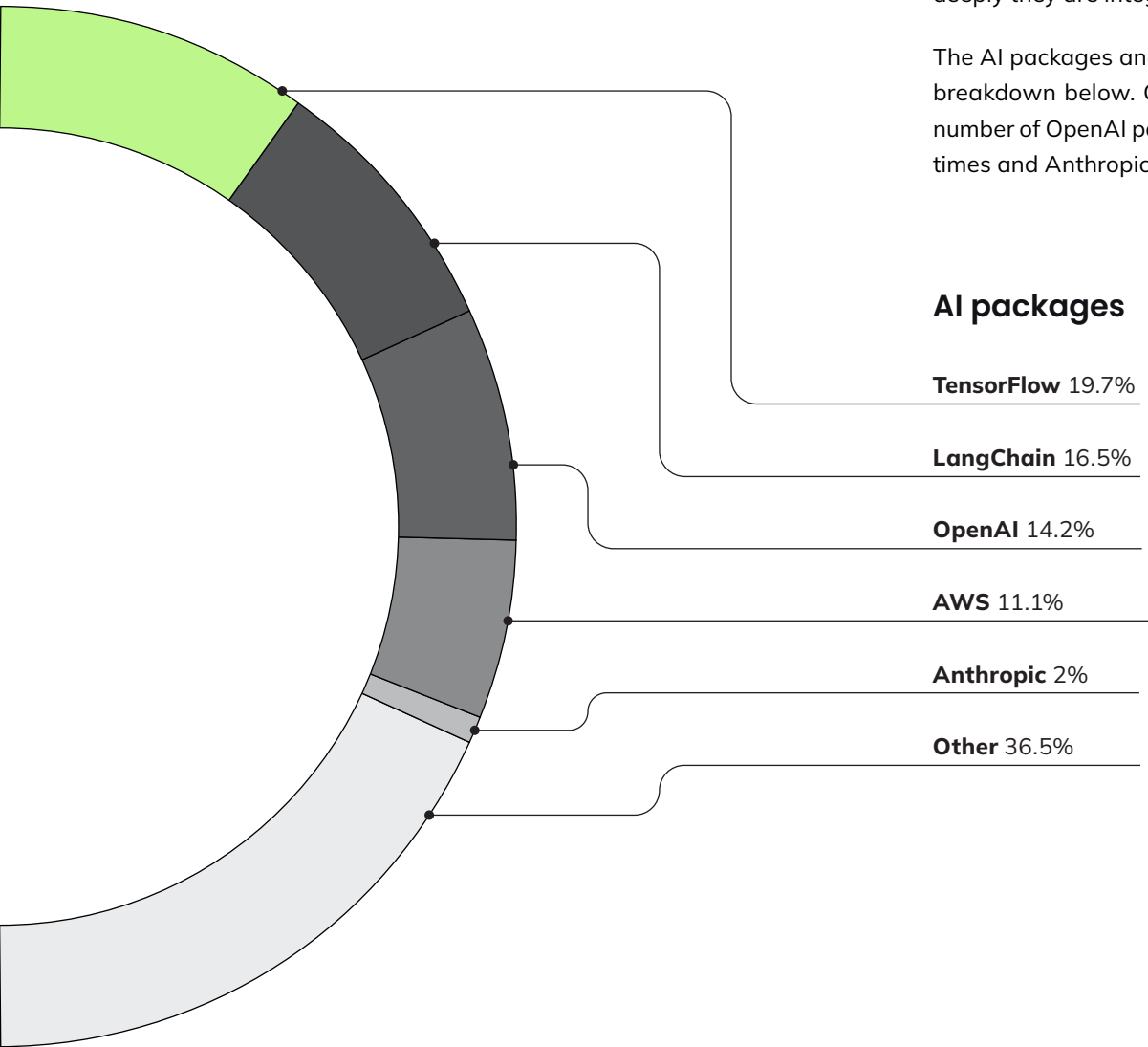
AI evolves from consumable to infrastructure

According to [McKinsey & Co.](#), AI adoption takes form in one of three categories: takers, makers, and shapers. **Takers** consume AI through third-party software-as-a-service (SaaS) platforms, like Salesforce and Snowflake, or hosted models like ChatGPT and Claude. They benefit from AI without the deep engineering integration requirements. **Shapers** are customizing and deploying models like OpenAI or HuggingFace, developing data pipelines, and integrating directly into their products and workflows. They build products on top of AI systems and focus on fine tuning.

Makers build their AI models from scratch. They train their models using massive GPU capacity and vast amounts of data.

This year's data makes one thing clear: the majority of organizations are making and shaping AI. We analyzed over 1 million more AI and ML packages than we did last year, and found strong signals indicating that AI adoption is moving from the "toy" phase to a permanent part of infrastructure, which came as no surprise. There was 25 times growth in the number of AI-specific packages year over year, but the presence of nearly six times more ML packages in cloud environments indicates that organizations are increasingly operating as shapers. The question is no longer whether or not organizations are using AI, but how deeply they are integrating it.

The AI packages analyzed included the breakdown below. Of significance, the number of OpenAI packages grew by 14 times and Anthropic by 40 times.



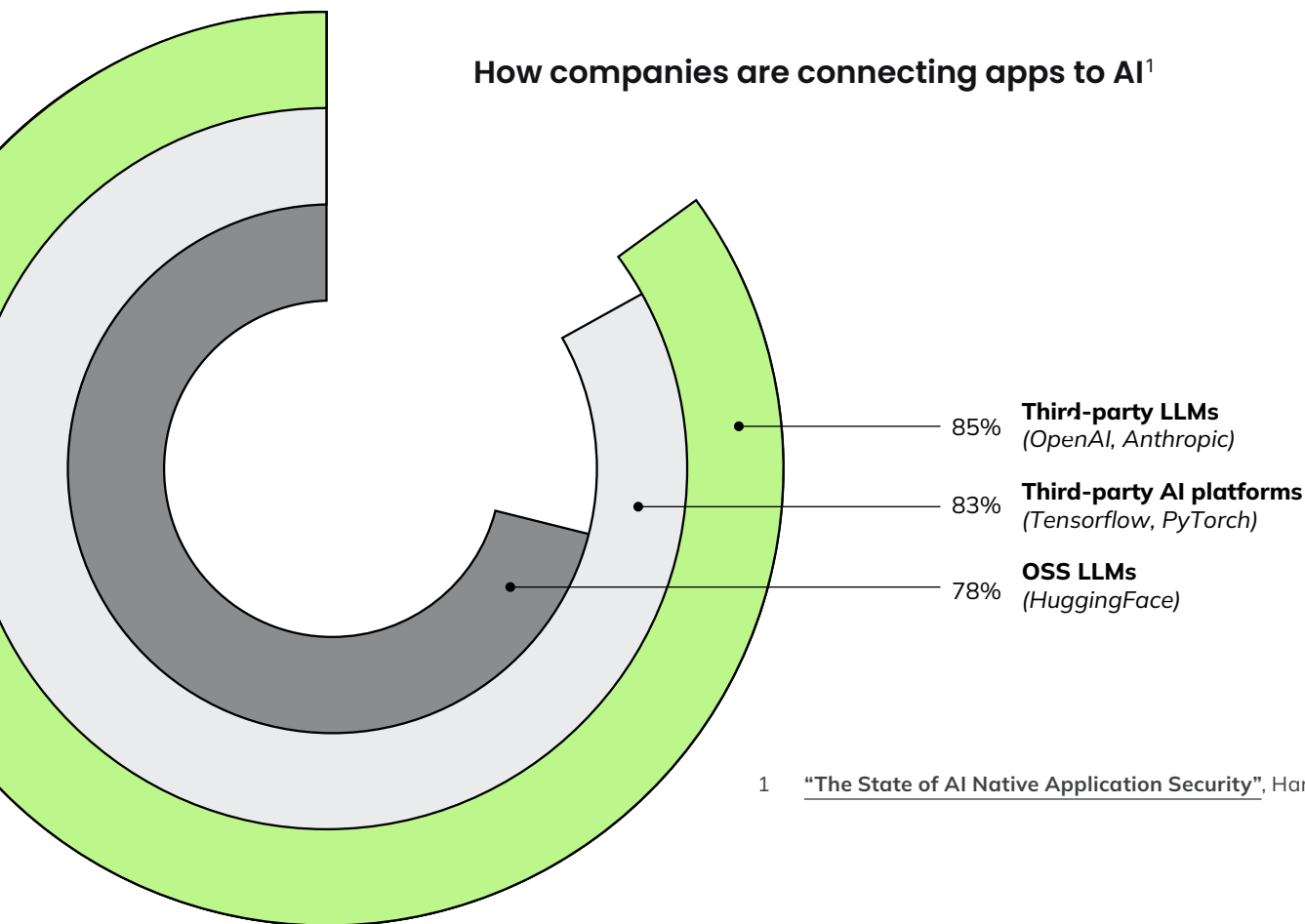
AI packages

- TensorFlow 19.7%
- LangChain 16.5%
- OpenAI 14.2%
- AWS 11.1%
- Anthropic 2%
- Other 36.5%

This growth data indicates that organizations are demonstrating good security hygiene in a new phase of security maturity. The spike in ML packages reflects the foundational work required to develop and support AI adoption. Rather than deploy AI-specific libraries, organizations are investing in the underlying ML foundations, prioritizing making AI over taking or shaping. Organizations are also building better data pipelines, monitoring processes, and evaluation tools to make AI that is scalable and governable. And engineers are integrating ML into areas that don't require AI-specific libraries such as forecasting, anomaly detection, reporting, and workflow optimization.

The data suggests that AI is being moved out of the code layer and into infrastructure and APIs. This is also reflected in broader industry research, as seen in the graph below. These patterns reinforce that AI is already highly consumed and operationalized through external services and shared platforms, and increasingly embedded directly into application code. AI packages that were once directly embedded in production are being replaced by custom internal services that make API calls to hosted models. What began as distributed and experimental work for some is being consolidated into meaningful standardized infrastructure and data workflows that can scale more efficiently and predictably. Consolidation makes way for shared inference, centralized tuning, and consistent cost controls.

How companies are connecting apps to AI¹



¹ [“The State of AI Native Application Security”](#), Harness

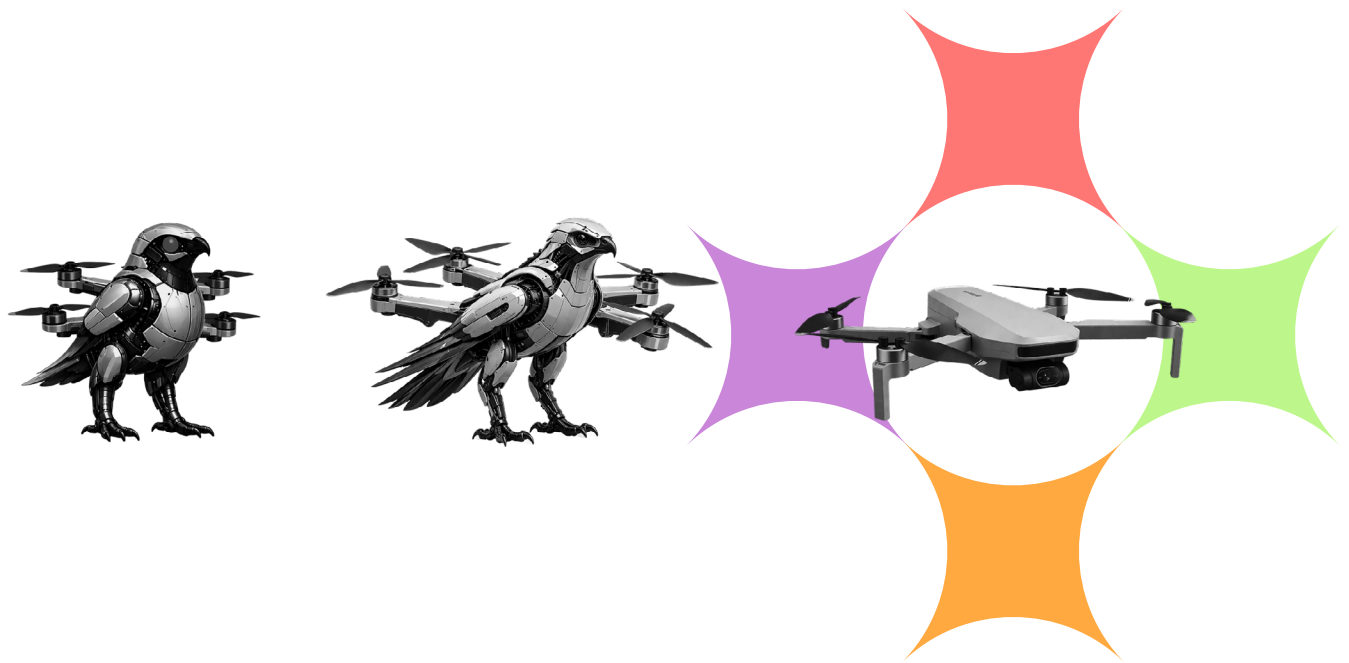
This standardization is also important for security, allowing teams to focus their efforts on a more critical set of the model infrastructure rather than an endless sprawl and attack surface of individual AI-enabled capabilities (even though the numbers are still growing). A centralized model infrastructure also allows for stronger access controls, faster patching, better monitoring, and clearer ownership.

Despite the vast increase in the number of data points reviewed, public exposure of AI and ML packages remained largely the same as last year at 1.5%; AI-specific exposure was 3.3%. Low exposure means that the majority of deployments are internal or behind protected layers because organizations are keen to protect their intellectual property. A centralized internal AI infrastructure enables secure scaling and consistent governance, and supports long-term operational maturity.

While low public exposure reduces some risk, it does not eliminate it. The AI attack surface can be extensive, so overly permissive accounts with access to data pipelines, misconfigured storage buckets housing training data, prompt injection, and supply chain risks are still concerns for nonexposed models. Additionally, an available Model Context Protocol (MCP) server introduces a new route of exposure beyond what is explained here. Rather than exposing inference interfaces directly, MCP servers expose the connective layers between models and the tools, data, and systems they can act on.

As organizations centralize AI infrastructure to enable secure scaling and consistent governance, these connective layers will become critical security priorities. Low exposure is a positive signal, but sustaining AI security requires proactive governance of models, data, and agent infrastructure as adoption continues to accelerate and agentic systems operate with greater autonomy.

As organizations centralize AI infrastructure to enable secure scaling and consistent governance, these connective layers will become critical security priorities.



Who leads in AI adoption

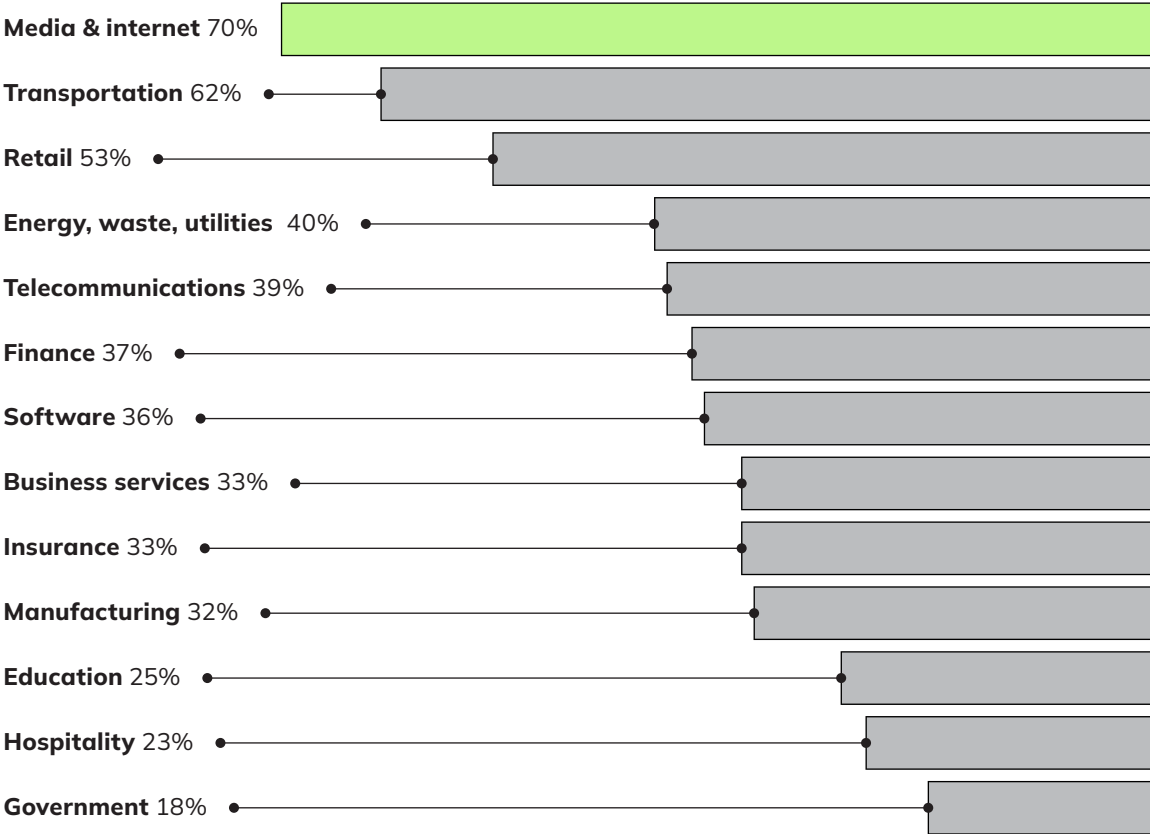
Many organizations are investing in AI as a product and experience differentiator, but while some are using third-party offerings to quickly hit the ground running, others appear to be building AI capabilities from the ground up. The line of differentiation is drawn by target audience (consumers or other businesses) and compliance requirements.

This section does not define the business sectors using the most AI across their organization because it does not account for connected third-party applications or AI enablement built into tools — in other words, quantifying the takers. This analysis focuses on the presence of AI and ML packages running in production environments.

It is clear that business-to-consumer (B2C) organizations like media and internet, transportation, and retail business sectors are leading with internal AI and ML deployments as shapers and makers. Since these industries rely greatly on end user and customer happiness, building their own, deeply integrated and unique internal AI tools is important to having a competitive edge. Their business operations demand continuous feedback loops, low tolerance for latency, and a high volume of behavioral data. In these cases, their AI efforts drive revenue and are tied directly to customer experience, engagement, and differentiation.

On the other hand, business-to-business (B2B) organizations such as software, business services, and manufacturing are very likely using AI extensively, but AI is likely embedded in third-party SaaS platforms and therefore less visible at the package level for this analysis. It's also possible that these organizations have a lower AI and ML package presence because their AI teams are centralized, or they have intentionally fewer deployment cycles given strict change-control processes. AI usage in these business sectors is for improving operational efficiency. B2B AI usage is more likely to support internal productivity, analytics, automation workflows, and customer support, as opposed to serving as the primary product interface.

AI adoption by business sector



AI adoption patterns vary significantly by business sector — not necessarily by how much AI is used, but where it exists. The differentiator is structural: B2C organizations internalize AI for differentiation and revenue acceleration, whereas B2B organizations use it for efficiency and more controlled risk exposure. Makers and shapers face infrastructure and model security challenges, while takers have supply chain, transparency, and vendor risk considerations.

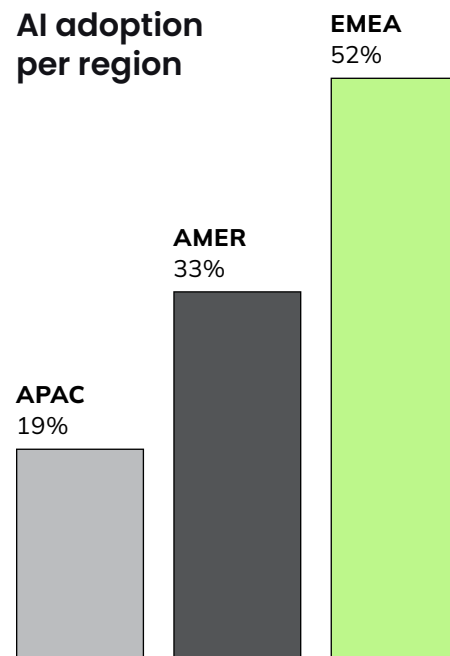
EMEA is vastly outpacing other regions in the adoption of AI and ML packages. This is a fascinating, seemingly counterintuitive finding on its face. Rather than stifling innovation, the EU's clear AI regulatory guardrails appear to provide

the necessary framework for cautious organizations to accelerate adoption confidently. With regulatory guidance in place, organizations operating in EMEA countries seem to feel more comfortable fully embracing AI innovation.

At the same time, this may simply indicate regional usage preferences. Organizations in EMEA may be more inclined to make and shape AI, driven by data sovereignty requirements and compliance considerations. The numbers do not account for organizations acting as takers, relying heavily on hosted AI services. Regardless, the data indicates that EMEA-based organizations are investing in internal AI infrastructure.

Rather than stifling innovation, the EU's clear AI regulatory guardrails appear to provide the necessary framework for cautious organizations to accelerate adoption confidently.

AI adoption per region



Resource integrity

AI and ML packages are the software bundles that a workload runs to perform specific tasks. In order to perform those tasks, a system needs consumable compute resources that, in the cloud, are often containers or virtual machines (VMs).

Rather than focusing solely on the security of AI and ML packages running in production environments, we dug into how these packages interact with surrounding resources.

We found that just 0.05% of resources are publicly exposed, with an average of 32% of packages being AI. This near-zero level of exposure likely reflects strong infrastructure hygiene. Organizations are largely following modern infrastructure security practices, such as private by default architectures, controlled exposure using ingress points, and continuous monitoring to detect misconfigurations.

When public exposure does occur, it is typically deliberate and concentrated at the endpoint or workload level, for example, web servers, customer-facing API endpoints for AI services, or public cloud storage buckets.

0.05% of resources were publicly exposed, with an average of 32% of packages being AI.

Key takeaways

AI is no longer experimental or a novelty. It is operational infrastructure. The growth in AI and ML packages signals a shift from AI consumption to produc-

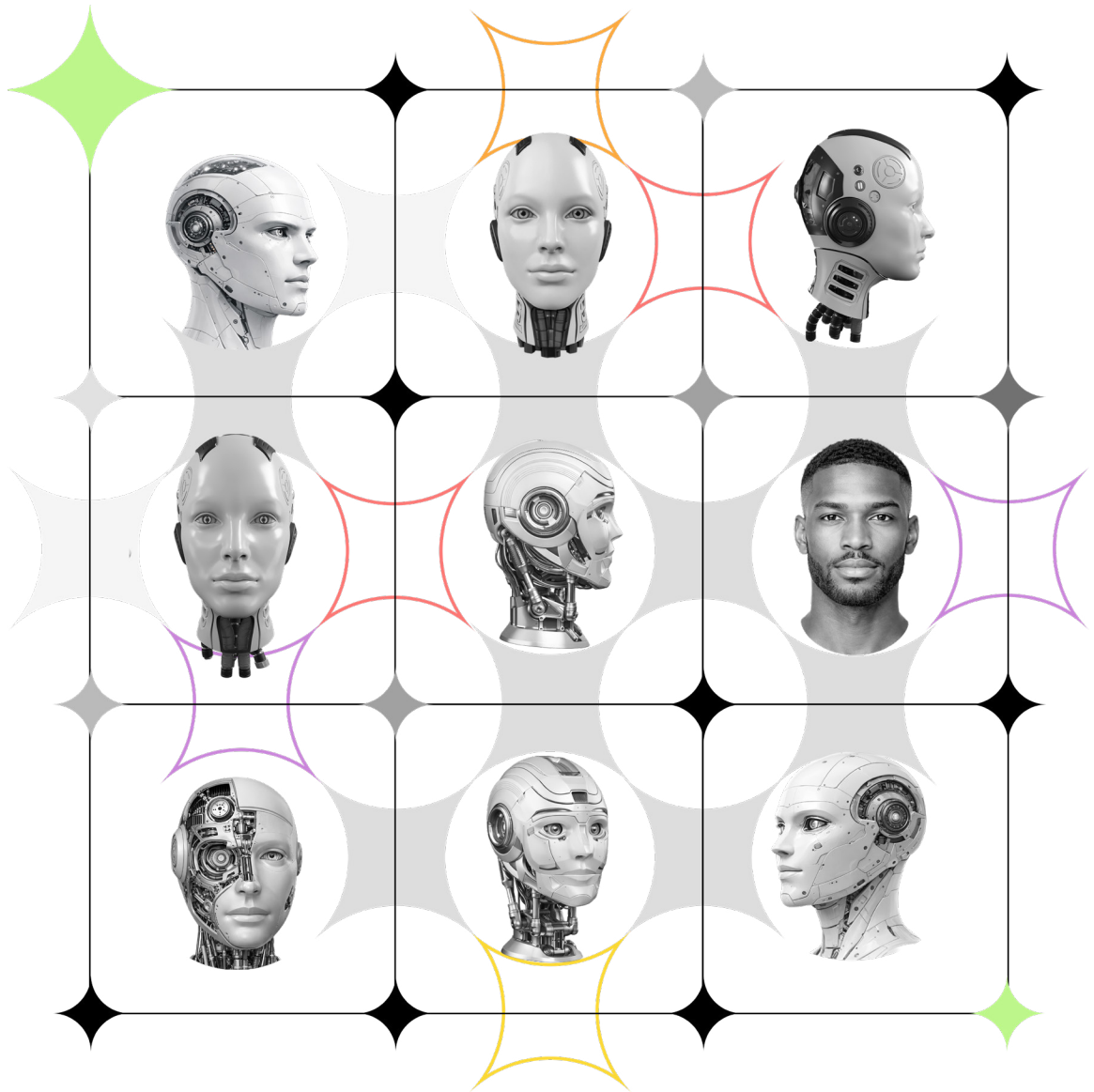
tion-grade making and shaping. The majority of organizations are makers and shapers, bringing greater control but also greater responsibility.

Next steps



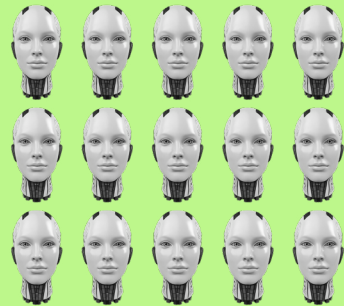
For those looking to improve **AI security**:

- Be explicit when making services internet-accessible by limiting access and/or requiring approval.
- Continuously audit for overly permissive identity access management (IAM) roles, machine accounts, and API tokens, especially those connecting data to models.
- Apply API security best practices like you would for an endpoint: authentication, rate limiting, input validation, as well as monitoring for abuse, prompt injection, and irregular data access patterns.
- Centralize model serving and inference where possible to reduce sprawl and simplify governance.
- Use policy as code, runtime detection, and continuous scanning to identify exposure early across infrastructure and APIs.
- Enforce automated expiration policies, tagging requirements, and unused resource cleanup to keep the software life cycle clear and tight.
- Apply zero trust principles to services, data pipelines, and APIs.
- Continuously monitor model behavior and data access patterns, not just infrastructure misconfigurations and changes.
- Assess third-party providers for supply chain security, transparency, and data governance, especially if your organization is a taker.



Identity is the cloud-native perimeter

Cloud identities are the new “firewall” of modern infrastructure. They exist to provide access to users (developers, operators, security teams) and machines (workloads, pipelines, services) to build, maintain, and connect the infrastructure. With them, we can establish who is allowed to do **what**, **where**, and **for how long**. Without identities, the cloud would rely on hard-coded secrets, shared credentials, and open access — all of which we know are conditions (and major security concerns) that attackers actively seek.



**Human
accounts
were only
2.8%
of all the
identities
analyzed**



Cloud-native identity management remains one of the most persistently misconfigured and poorly governed areas of security. Overly permissive or unused accounts and long-lived credentials are still the norm, not because organizations don't understand the concepts of least privilege or zero trust, but because identities in the cloud change and scale faster than humans can manage them. Every workload, pipeline, API, model, and automation script introduces additional identities and permissions. This is especially true as organizations deploy AI systems that interface with the cloud control plane because AI agents also use identities to assume roles, self-authenticate, and invoke APIs. The difference is the scale and autonomy involved. Now more than ever, it's important to look at the behaviors of identities to ensure that AI is acting within human-defined boundaries.

Identity management and the ability to properly govern identities has hit the same human limit as vulnerability management and detection. The uncomfortable truth is that people have never been good at managing identities at scale, and the scale only continues to grow. Mapping who can access what across environments and services in the new age of AI is not sustainable with periodic review and static policy audits. The modern cloud perimeter requires continuous analysis, contextual understanding of behaviors, and automated enforcement. These requirements make identity management an ideal use case for agentic AI.

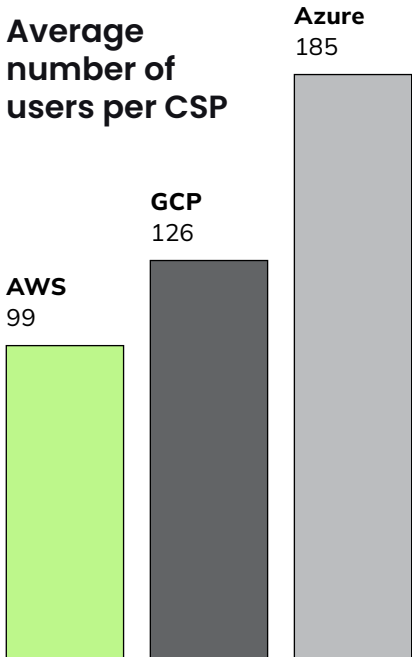
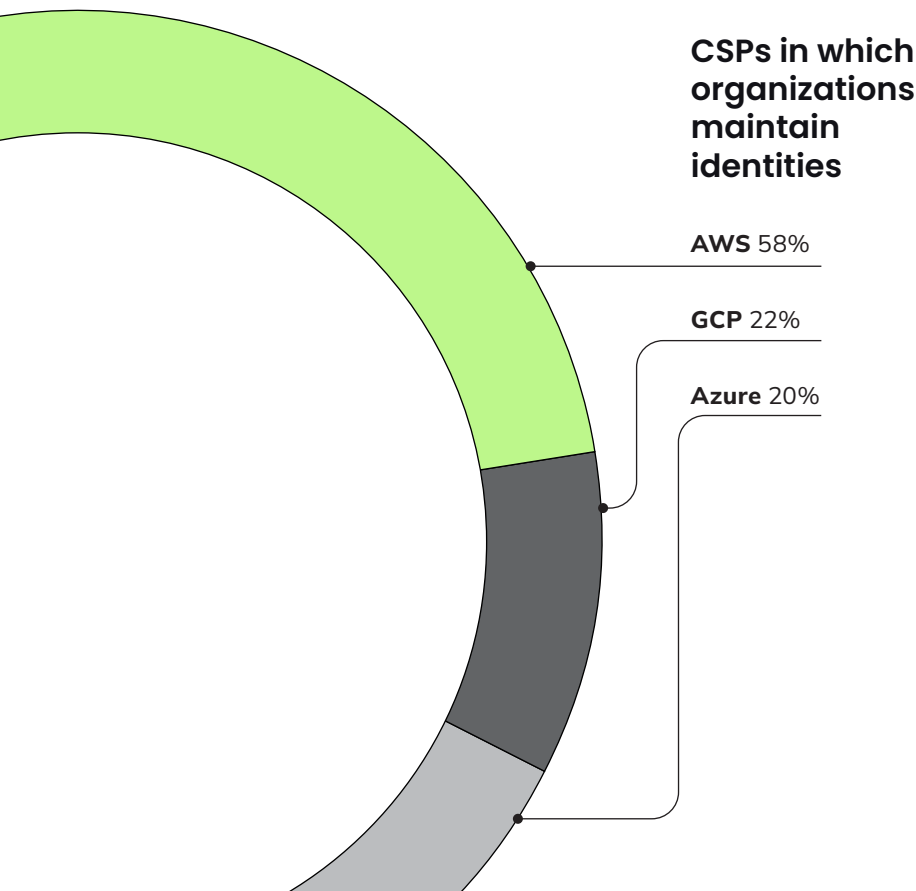
Identity distribution across CSPs

While a majority of organizations still tend to use AWS as their primary CSP, we saw an increase of 9% for Azure users over the last year.

Additionally, 24% of organizations maintain identities with more than one CSP. This has nearly doubled year over year.

There is a stark shift from last year in the average number of users per CSP. Previously, we reported more than 7,300 user identities on average in Azure environments. This 97% reduction is not a

decline in usage, but a clear overhaul and improvement for Azure identity security. Last year's elevated Azure user count was driven by how Microsoft Entra represented application-based authentication. This year's average shows normalization across the three CSPs. It shows that "security by design" as a provider effort can do more for noise and alert fatigue than an entire year of manual effort. However, despite continued improvements in tooling and knowledge of identity security, risk remains widespread across all CSPs for human and machine identities.



Humans are inherently risky

We defined a risky user as a human-owned account meeting at least one of the following parameters:

- Administrator privileges.
- No multifactor authentication enabled.
- Having access keys that are not rotated.
- Inactive for 90 days.

On average, 67% of user identities are considered risky across all CSPs. It's likely that administrator accounts, which are inherently highly privileged, are partially skewing this number. But even if those are false positives, there is still an innate risk associated with these accounts; to compensate, they need to be actively monitored for behavioral anomalies.

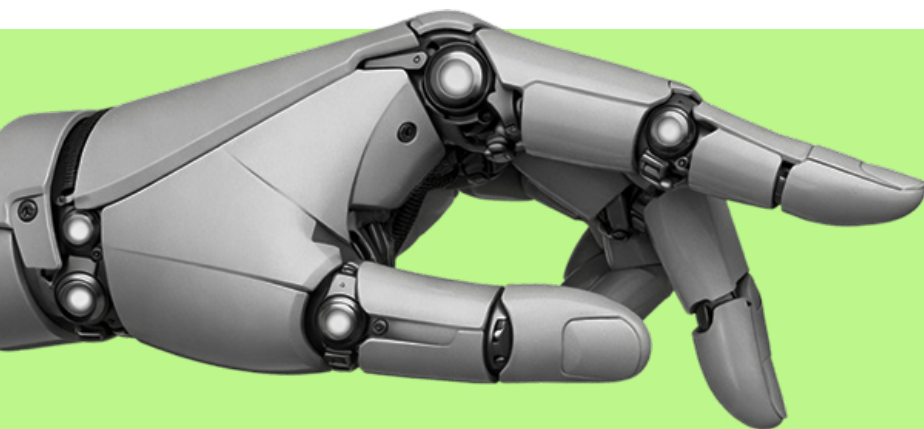
Even with providers' continued improvements to identity security, identity risk remains widespread across all providers. Tooling and visibility have improved, but scale outpaces human governance.

Average percentage of users with some risk consideration



Machine identity risk is a priority

The number of machine identities continues to grow by orders of magnitude over human identities. However, even with the increasing number of AI tools and MCP servers with elevated privileges, we witnessed a sharp decline in the risk associated with nonhuman identities that varies based on CSP. Machine identity security is a priority but remains a critical risk vector, especially as AI agents assume machine identities to interact with infrastructure and data. Excessive permissions or insufficient monitoring can allow agents to push beyond intended behavioral boundaries.



Define “machine identity”

We defined a risky machine identity as meeting at least one of these parameters:

- ✓ Administrator or editor-level permissions applied
- ✓ User-managed keys
- ✓ Multiple access keys active
- ✓ Access keys not rotated
- ✓ Inactive for 90 days

There are several different names given to machine identities across CSPs, all of which carry a fairly similar percentage of risky accounts:



- In AWS, a **role** is the primary machine identity. It can be assumed by Elastic Compute Cloud, Lambda, Elastic Container Service, Elastic Kubernetes Service, CI/CD systems, and more. **45.1%** of AWS roles are considered risky, even though their credentials are temporary and autorotated.
- AWS **IAM policies** are attached to roles. They define allowed and denied actions for roles but never authenticate on their own. **34.2%** of existing IAM policies are considered risky since they may maintain permissions that allow privilege escalation, resource deletion, or data exfiltration. While these permissions are likely assigned to roles intentionally for business operations, behaviors need to be monitored for abuse.



- A **service account** is the canonical machine identity used in GCP. They are assigned to compute engines, Google Kubernetes Engine, CI/CD systems, and more. **48.2%** of GCP service accounts are considered risky, which could be because of unused permissions or inactivity.
- GCP **roles** are the predefined permissions that cannot act alone. These are bound to the service accounts, and **36.1%** are considered risky because of their administrator permissions, unused permissions, and other reasons. Again, many of these risky findings may be false positives and intentionally assigned, but they require additional security diligence.



- In Azure, a machine identity is called a **service principal or managed identity**, which includes app identities and those managed by Azure. These include VMs, Azure Kubernetes Service (AKS), app services, and automation tools. **38.4%** of Azure machine identities are also risky because of unused permissions, administrator-level permissions, and other high-risk assigned permissions.
- Azure **roles** define the allowed actions that machine identities have access to. These are **31.9%** risky for inactivity or ownership with full administrator control of the environment.

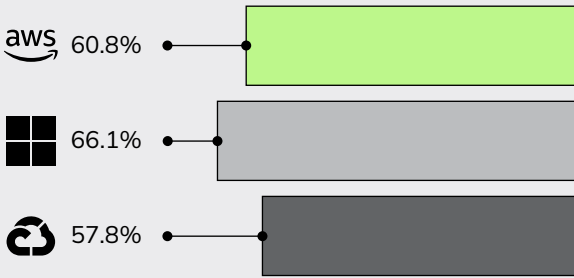
Higher percentages indicate the flexibility and overuse of machine identities across compute, CI/CD, and data service integrations where permissions are often granted to “just make things work.”

Cloud complexity drives risk

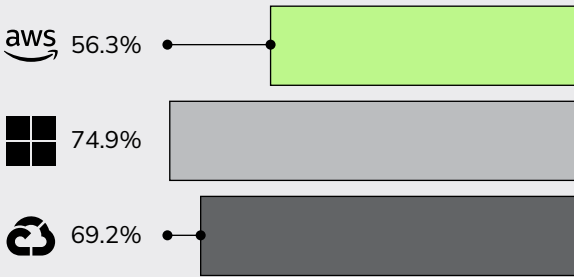
The impact of multicloud complexity is clear when looking at the risky users and roles based on single or multicloud usage. In multicloud environments, Azure and GCP show an increase in risky users, while AWS trends down slightly when compared to single cloud organizations.

Because of the AI boom and application sprawl, machine identities are innately difficult to manage. The higher machine identity risk in multicloud environments is likely caused by duplicated accounts, inconsistent policies, and fragmented ownership across CSPs.

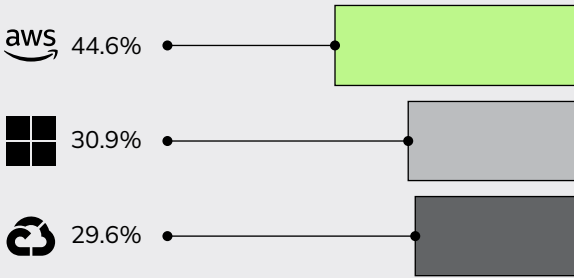
Single cloud risky users



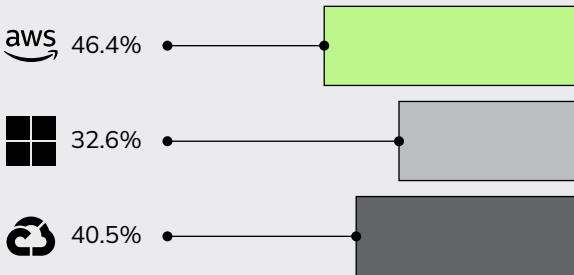
Multicloud risky users



Single cloud risky roles



Multicloud risky roles



Key takeaways

While some identities legitimately require elevated access, persistent high-risk permissions increase the likelihood and impact of a compromise. Both humans and machines accumulate risky permissions over time that are not always removed when business needs change. In cloud-native and AI-driven environments, that negative accumulation compounds quickly.

The next level of identity management, to maintain the security perimeter, calls for continuous, automated governance. The AI boom has expanded the

number of machine identities in cloud environments, compounding the identity management challenge that security teams were already struggling to control like over-provisioned and unused permissions and an excessive number of identities. Humans should define acceptable risk and a governance strategy before using agentic systems capable of continuously analyzing behavior patterns, right-sizing permissions, removing unnecessary privileges, and enforcing policy guardrails.

Next steps

Successful organizations will be those using autonomous systems to shrink their identity attack surface. Other tasks include:

- Applying the principle of least privilege dynamically, based on observations instead of just static assumptions or policies.
- Using temporary privilege elevation and just-in-time access instead of persistent administrator access where possible.
- Defining parameters for unused or rarely used permissions and automating their removal.
- Rotating or eliminating long-lived keys in favor of short-lived and autonomously rotated credentials.
- Using policy controls to proactively block unauthorized high-risk permissions.
- Monitoring identity behavior continuously, alerting on unexpected actions or privilege escalation.
- Consolidating identity management in multicloud environments to rescue duplicated accounts and inconsistent policies.



Growth of the open source runtime security community

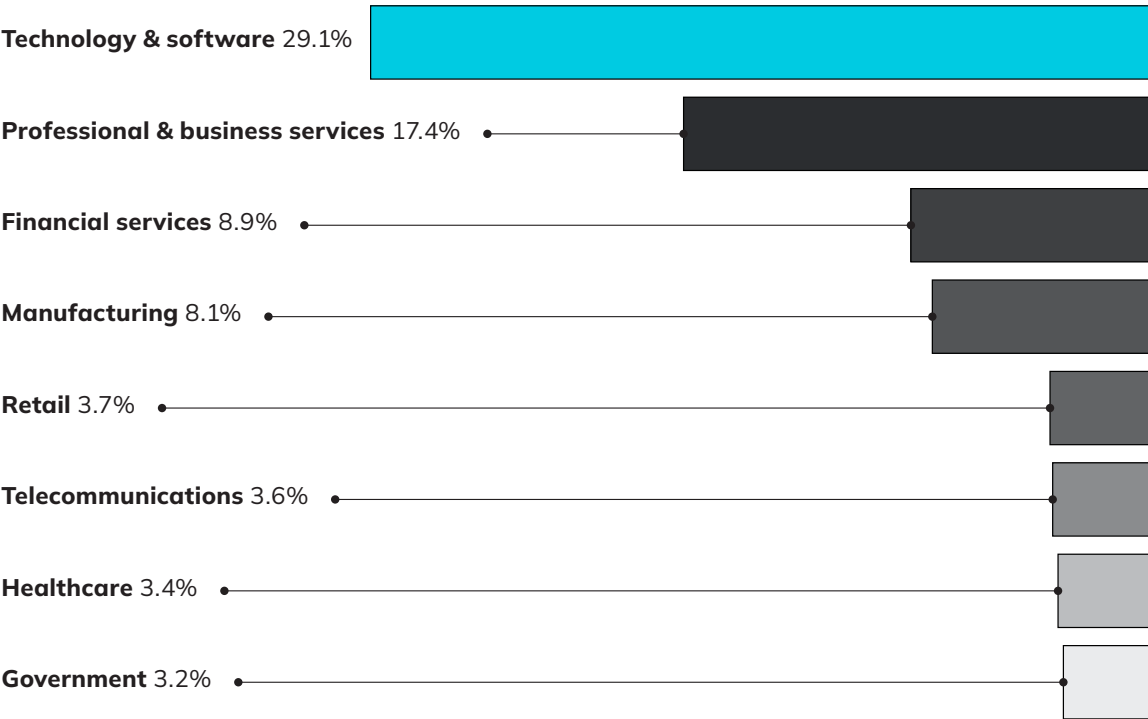
There are over 9,000 organizations using Falco, ranging from interested parties and those testing out the tool to persistent, longtime users. As the hustle hard era comes to an end, organizations are increasingly looking for and relying on systems capable of scaling beyond their individual security teams, but these can sometimes come at a cost. Falco is an open source cloud-native runtime security tool that offers real-time detection, alerting on abnormal behaviors and potential security threats. It works at machine speed, it's transparent, and it's the kind of scale you can't pay for because it's maintained by a global community.

Vertical adoption

The highest usage by industry shows that organizations in the business of serving others use Falco the most. These organizations likely have customers that span a variety of highly regulated industries, operate distributed infrastructure, and innovate or move rapidly — meaning that being able to customize threat detection and response and look under the hood of the engine is important to them. They're a natural fit, often with developers and cloud-native enthusiasts who are most likely to adopt open source tools.

Others span highly innovative industries evolving quickly with AI, like manufacturing and retail. These organizations need flexible security that matches rapid digitalization; they may need to secure increasingly complex production lines. And finally, organizations in highly regulated sectors, like healthcare and government, need transparent security solutions that are suitable for their unique environments.

Top industries using Falco

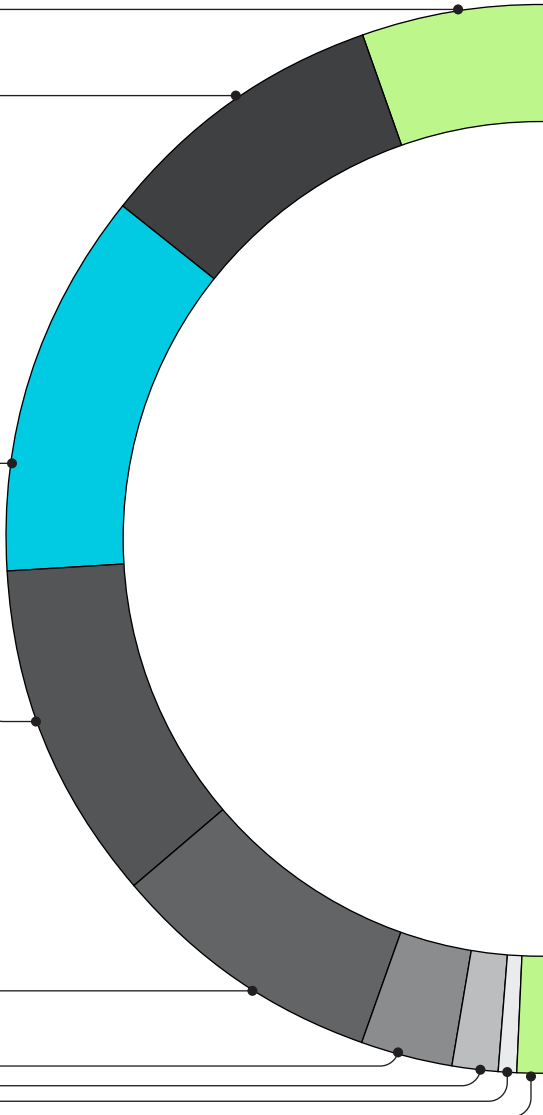


Scale without limits

Similar to last year, the size of an organization makes no difference whether they use an open source tool for threat detection and response or not. This consistent data point underscores the universal appeal of runtime security and open-source security, and proves that Falco scales from start-up to Fortune 500.

Falco use by organization size

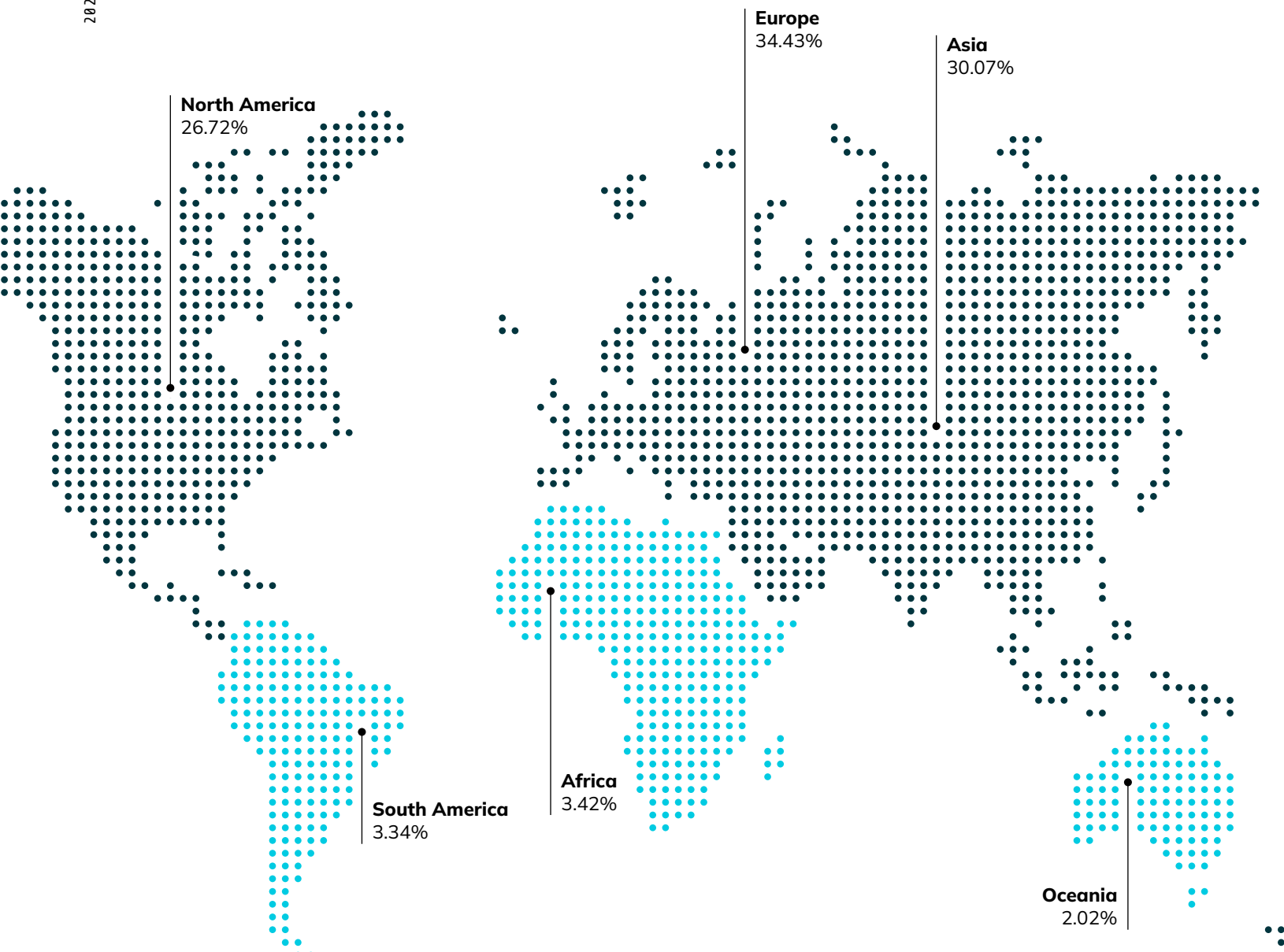
1-10	10.8%
11-50	17.8%
51-250	23.2%
251-1K	20.8%
1K-5K	16.7%
5K-10K	5.6%
10K-50K	2.7%
50K-100K	1.2%
>100K	1.2%



Open source is a universal language

Falco has roots that spread across the world with persistent growth year after year; it's a global standard for runtime detection, especially in those countries that require data sovereignty and covet open source.

Falco use by continent

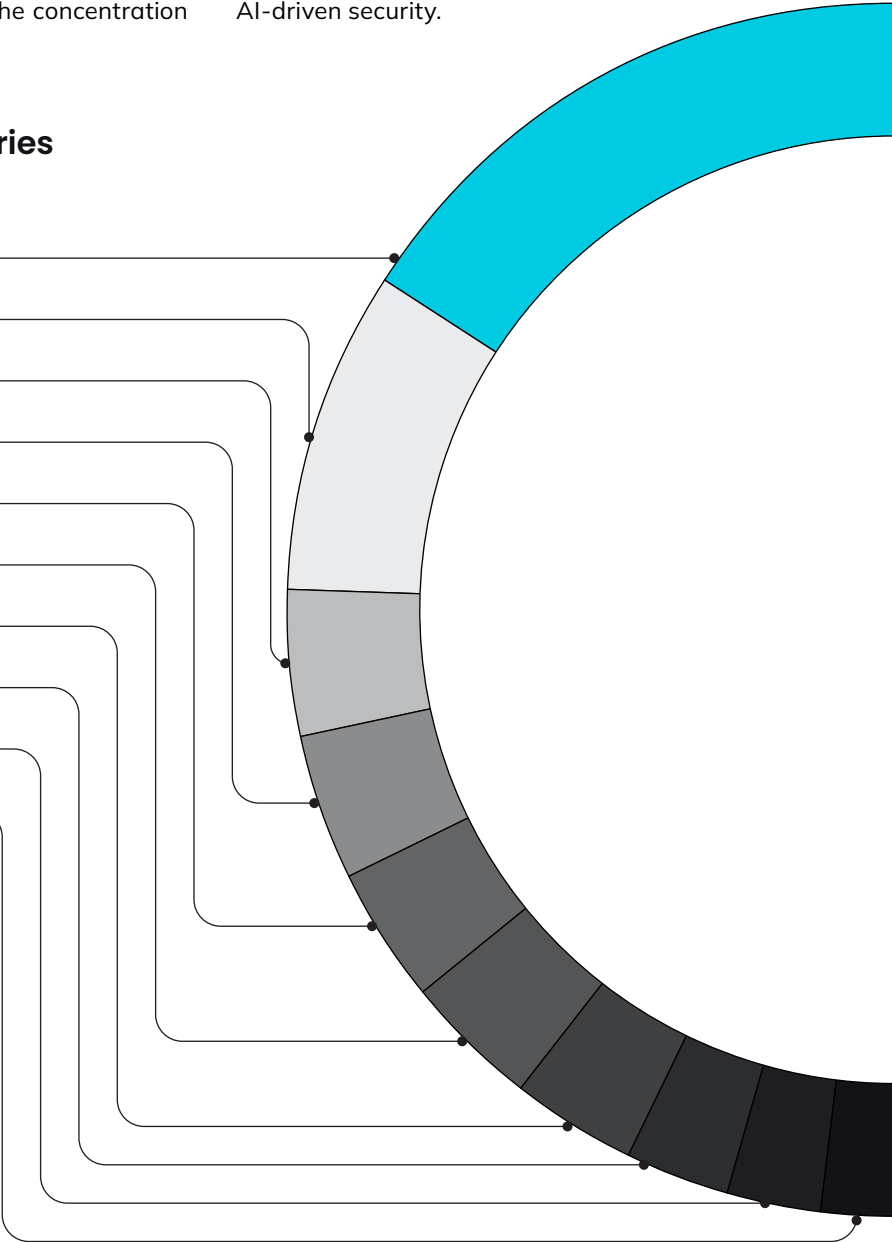


Falco’s growth in Europe is catalyzed by an intense legal push for data sovereignty. Open source security tools are the primary vehicle for achieving data sovereignty because they remove the dependency on non-European Union (EU)-based proprietary black boxes. Under the EU Cloud Sovereignty Framework’s Sovereignty Effectiveness Assurance Level 4 (SEAL-4), organizations must maintain full EU-based control of technology and operations, subject only to EU law, and with no critical dependencies outside of the EU, ideally for each of the eight objectives. The concentration

of user organizations in Germany and France is expected, as these countries are the primary drivers of the EU Cloud Sovereignty Framework. Together representing over 42% of EU Falco adoption, this signals that the largest economies in Europe are moving past proprietary tools. By standardizing on Falco to defend their sovereign cloud initiatives, these organizations are ensuring that they meet the requirements of the Digital Operational Resilience Act, the EU AI Act, and the EU Cloud Sovereignty Framework, and align with the future of AI-driven security.

Top 10 EU countries for Falco usage

Germany	25.6%
France	13.7%
Netherlands	6.5%
Italy	6.2%
Spain	5.9%
Belgium	5.8%
Poland	5.4%
Switzerland	4.5%
Sweden	4.0%
Ukraine	3.1%



Key takeaways

The rise of open source runtime security mirrors the shifts seen throughout the report: humans cannot continuously tune permissions, triage alerts in real time, or outpace exploit weaponization. What they can do is build and trust systems that operate at the timescales necessary to act quickly.

Falco's growth provides a growing consensus that runtime detection is the foundation for automation and agentic security. While the hustle hard era may be ending, the community is accelerating. Machine-scaled security will be built on global standards, transparency, and systems designed to operate autonomously within those parameters.

Next steps

It's time to operationalize this momentum. To do so, organizations should:

- Adopt runtime as a foundational control.
- Use high-fidelity, behavior-based runtime detections that can safely power autonomous response.
- Leverage open source security tools to increase transparency, auditability, and breadth of detection logic.
- Align runtime detections with regulatory and sovereignty requirements.
- Invest in human-driven detection engineering to drive rule tuning, validation, and maintenance as a precursor to safe agentic security.

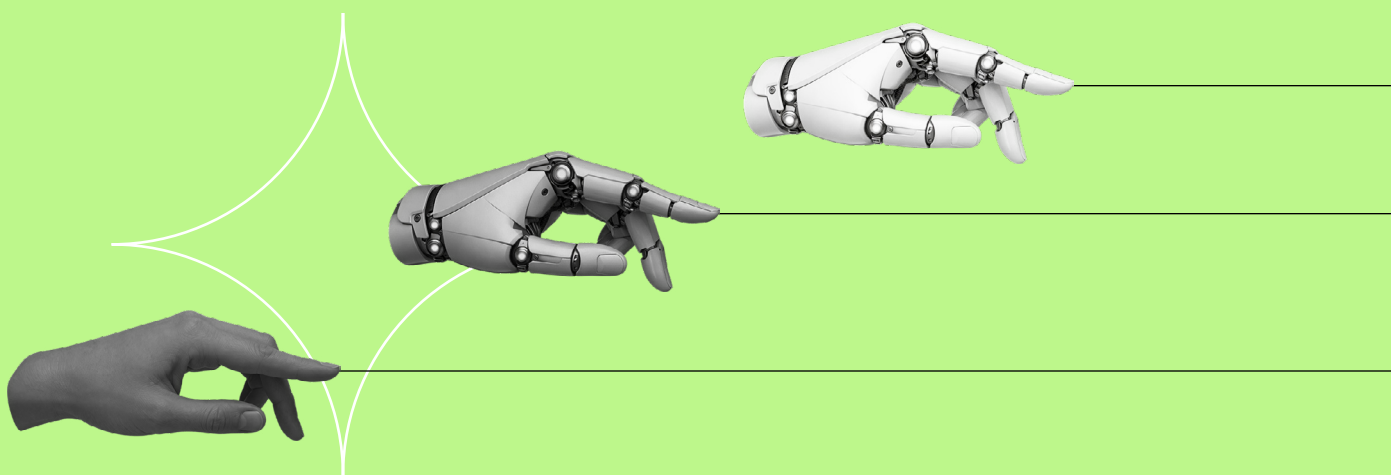
Conclusion

We've officially moved past human scale in cloud security. We're entering the machine-scale era.

Some attackers have been operating at machine speed for a few years now. At this point, the risks in cloud environments will persist, as humans cannot manually clear the multiple security backlogs fast enough. From this year's data, we see that the transition is already underway with improvements to signal concentration and higher fidelity, growing trust in automated actions, and a focus on reducing the right risks first.

Security and perfection are certainly not synonymous, and that's not what we're pushing for. Mature security operations prioritize the right priorities over everything, at scale. Organizations are already trusting machines to make recommendations and complete tasks to enhance business operations. The next step is trusting them with security workflows and decisions to keep those business operations moving forward.

Agentic AI isn't a leap of faith, but the logical progression of security automation. Once detection and response are trusted, autonomous prevention and remediation are the obvious next frontier. The goal is real risk reduction beyond the limits of human speed and scale.



Methodology

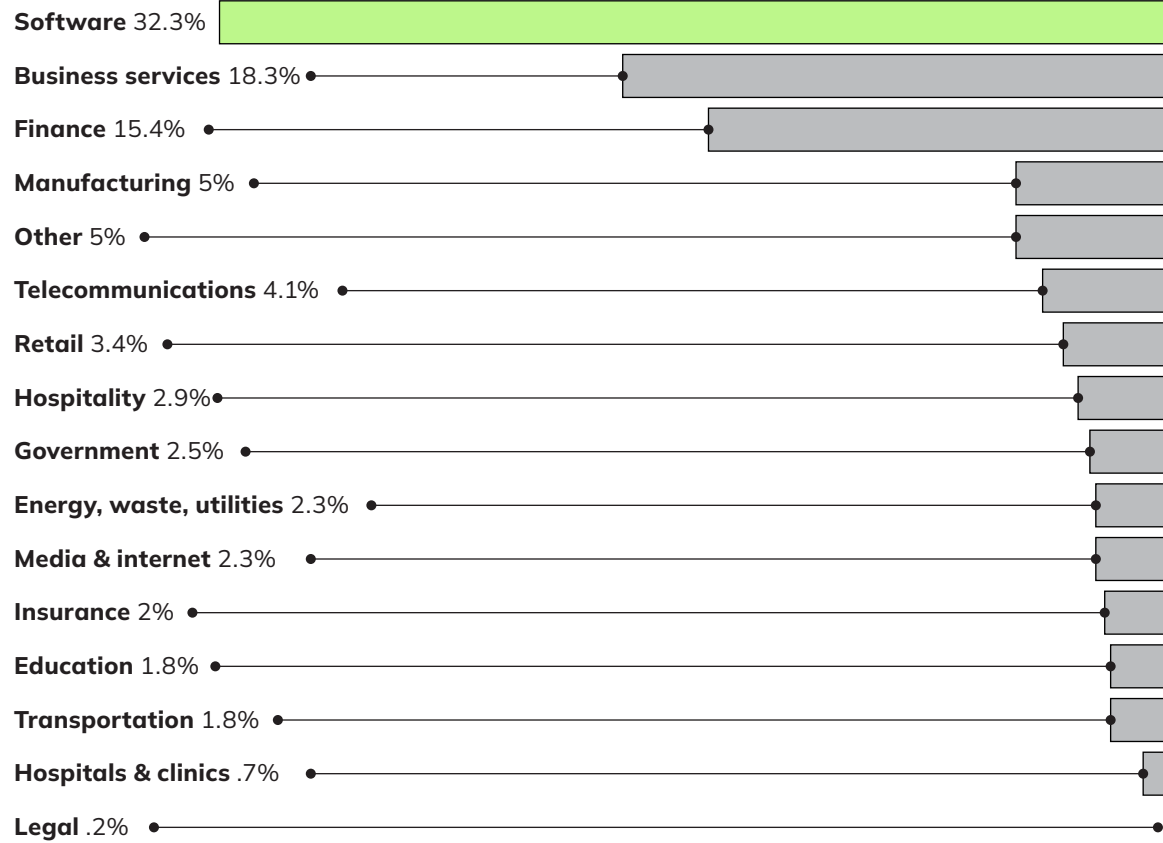
The “2026 Cloud-Native Security and Usage Report” is built from the real-world telemetry and behavioral patterns of hundreds of thousands of cloud accounts and billions of Kubernetes containers secured by Sysdig daily. This year’s analysis represents our most expansive datasets to date, reflecting a modern landscape with growing and expanding data given the shift from manual to autonomous practices.

From agile startups to multinational enterprises, our anonymized data spans a wide range of cloud-savvy organizations across the globe, ensuring a representative view of security maturity. We also used Scarf for open source project usage analysis to facilitate data gathering.

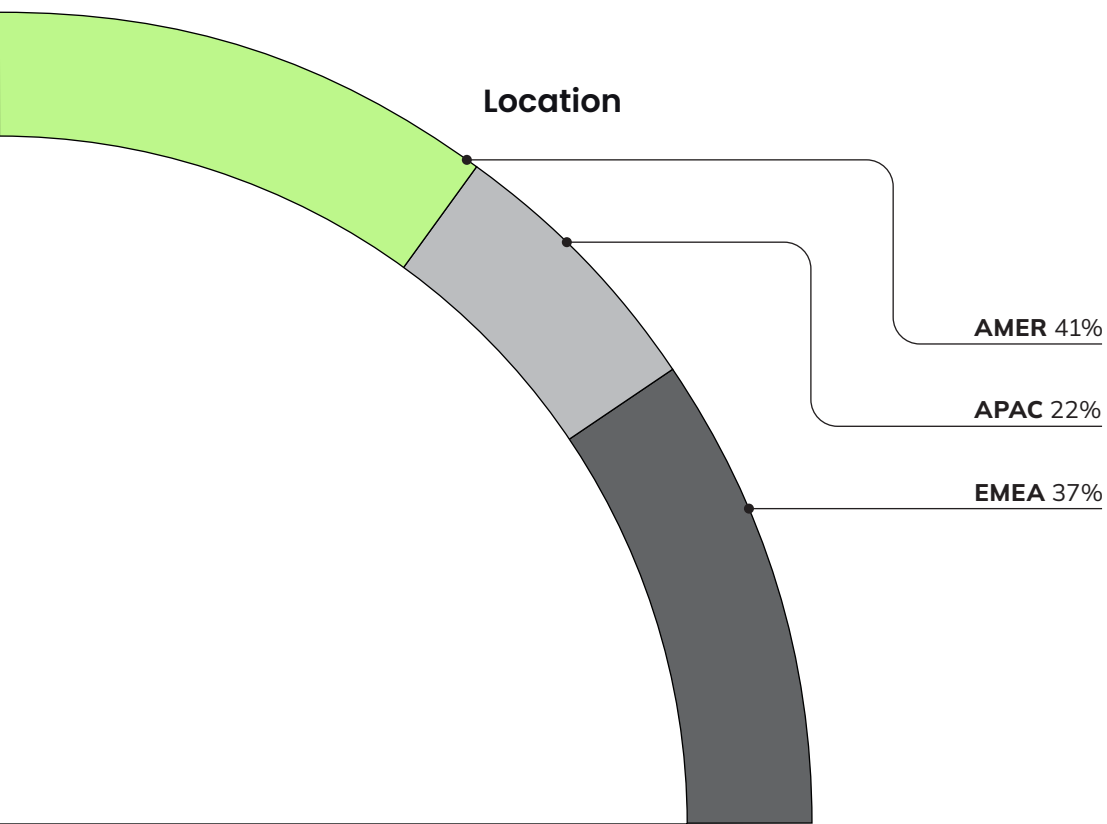
Our findings provide a look at the evolving tactics of attackers and defensive shifts within cloud-native ecosystems. Sysdig, with roots in Wireshark, Falco, and Stratoshark, is passionate about the open source philosophy of information sharing. The concepts and analyses in this report are a culmination of insights from engineers, product managers, threat researchers, marketers, and executives whose perspectives span the organization, providing you with the actual changing aspects of cloud, container, and security trends.

Where does our data come from?

Business sector



Location



Sysdig helps security
and development
teams prevent, detect,
and respond to threats
instantly. No guesswork.
No black boxes. Just cloud
security, the right way.

[GET A DEMO](#)

sysdig

USAGE REPORT

COPYRIGHT © 2026 SYSDIG, INC.

ALL RIGHTS RESERVED.

RP-017 REV. A 04/26
